404 烦恼未找到
系统设计说明书

软件工程团队实践第三次作业

目录

1 引言 4
1.1 编写目的 4
1.2 项目概述与范围 4
1.3 编制依据与配置基线 4
1.4 缩写与术语 5
2 总体设计 6
2.1 设计目标与分层 6
2.2 系统体系结构 7
3 功能模块层次设计 8
3.1 功能层次 8
3.2 模块职责与输入输出 9
3.3 前端分层与状态归属 9
3.4 多入口能力边界 11
4 详细设计与设计类图 13
4.1 表达规则与类职责 13
4.2 账号与入口身份 14
4.3 临时业务活动 15
4.4 保存记录与用途授权 16
4.5 端侧互动与物理音频 17
4.6 应用服务与仓储适配 18
4.7 接口数据类型 19
4.8 类型约束与聚合不变量 20
5 接口设计 24
5.1 接口目录与调用契约 24
5.2 全局协议与技术约束 27
5.3 共享会话、授权和 Agent 契约 30
5.4 REQ01 陪伴交流 33
5.5 REQ02 压力缓解小训练 33
5.6 REQ03 信息查询 33
5.7 REQ04 模式切换 34
5.8 REQ05 会话和记录控制 34
5.9 REQ06 多入口及桌宠 35
5.10 REQ07 安全与隐私 36
5.11 REQ08 情绪与事件日历 36
5.12 REQ09 情绪命名卡 36
5.13 REQ10 烦恼物件化 37
5.14 REQ11 平行宇宙排练 37
5.15 REQ12 烦恼寄存 38
5.16 REQ13 屏幕无损发泄 38
5.17 REQ14 文字销毁 38
5.18 REQ15 禅意编曲弹珠机 39
5.19 REQ16 注册、登录与改密 39
5.20 REQ17 私密个人主页 40
6 运行过程与关键状态 41
6.1 任务控制与迟到回复 41
6.2 沟通排练 42
6.3 保存清除与不确定写结果 44

6.4 停止与资源回收 46
7 数据协作设计 46
7.1 临时与持久对象 46
7.2 类与表映射 46
7.3 事务与恢复协作 47
8 安全与权限设计 48
8.1 权限判定 48
8.2 安全措施与失败行为 48
8.3 文字销毁独立通路 49
8.4 内容与危机边界 51
9 部署维护与健壮性 51
9.1 运行配置 51
9.2 故障处理 51
9.3 维护与变更 51

1 引言

1.1 编写目的

本说明书供开发成员、测试人员及课程评审阅读，说明 404 烦恼未找到的总体结构、模块职责、类与接口、运行控制和安全边界。阅读顺序由系统概貌进入模块、设计类、调用协议和运行验收，使未参与前期讨论的技术人员能够据此组织开发。

1.2 项目概述与范围

系统面向个人的情绪表达、烦恼整理、沟通排练和压力缓解。六个模块覆盖 REQ01 至 REQ17。用户可以先体验临时功能，再决定是否主动保存选定内容；日历只记录不分析，寄存到期只提示可取出，文字销毁采用独立端侧通路。

本说明书依据项目设计材料和 React/Vite 演示原型编制，规定系统的模块职责、接口契约与数据约束。文中的接口、配额和安全措施均为设计约定。

本版不包括密码找回或重置、账号注销、公开主页、社交关系、烦恼漂流瓶、管理员业务后台或自动跨入口同步。登录不迁移游客临时内容，退出不删除已保存记录。库内存在的 ANALYZE、CROSS_ENTRY 用途枚举属于既有模型表达，不构成本轮开放分析或跨端同步接口的承诺。

1.3 编制依据与配置基线

项目仓库为 impureWine/404NOTFOUND，分支 main，本版固定提交为 fe60c90c1ed3c392bd0946f794c96ea53cc29711，核对日期 2026 年 10 月 22 日。两份说明书采用同一快照；原设计作者与职责沿用仓库，不将本次整理视为成员签认。编制依据见本节。

采用 GB/T 8567—2006《计算机软件文档编制规范》作为文档组织参考，围绕引言、设计约束、结构与模块、接口、数据、运行、保护、维护及追踪逐层展开。具体项目内容和课程评分条目作适用性裁剪，不声明经过第三方标准符合性认证。

参考资料：GB/T 8567—2006《计算机软件文档编制规范》（国家标准全文公开系统）；课程第三次团队作业要求；GitHub 项目仓库 impureWine/404NOTFOUND 的本版固定提交。

1.4 缩写与术语

缩写或术语	定义
SRS	软件需求规格说明书
REQ 与 AT	项目需求编号与对应验收场景编号
UML	统一建模语言，用于表达类、属性、方法及关系
ER 与 PK FK UK	实体关系模型与主键、外键、唯一键
API HTTP REST DTO	应用程序接口、超文本传输协议、资源式接口风格、数据传输对象
AI LLM Agent	人工智能、大语言模型、受应用服务限制的任务执行代理
SQL DDL DML	结构化查询语言、数据定义语言、数据操作语言
UUID UTC JSON	通用唯一标识符、协调世界时、JavaScript 对象表示格式
CSRF Origin Cookie	跨站请求伪造防护、请求来源、浏览器会话凭据载体
XSS SSRF	跨站脚本攻击、服务端请求伪造
CSP TLS	内容安全策略、传输层安全协议
ESM JSX IPC DPI	JavaScript 模块规范、React 语法扩展、进程间通信、显示缩放密度
URL IP CPU DOM	统一资源定位符、互联网协议地址、中央处理器、文档对象模型
CDN SDK NFKC	内容分发网络、软件开发工具包、Unicode 兼容规范化形式
SHA-256 Argon2id	会话凭据所用 256 位安全摘要算法、密码所用带盐慢哈希算法
Repository pg Zod	数据访问端口、PostgreSQL 驱动、共享输入校验库
generation version	前者使旧异步任务失效，后者防止持久对象并发覆盖，二者不可混用

2 总体设计

2.1 设计目标与分层

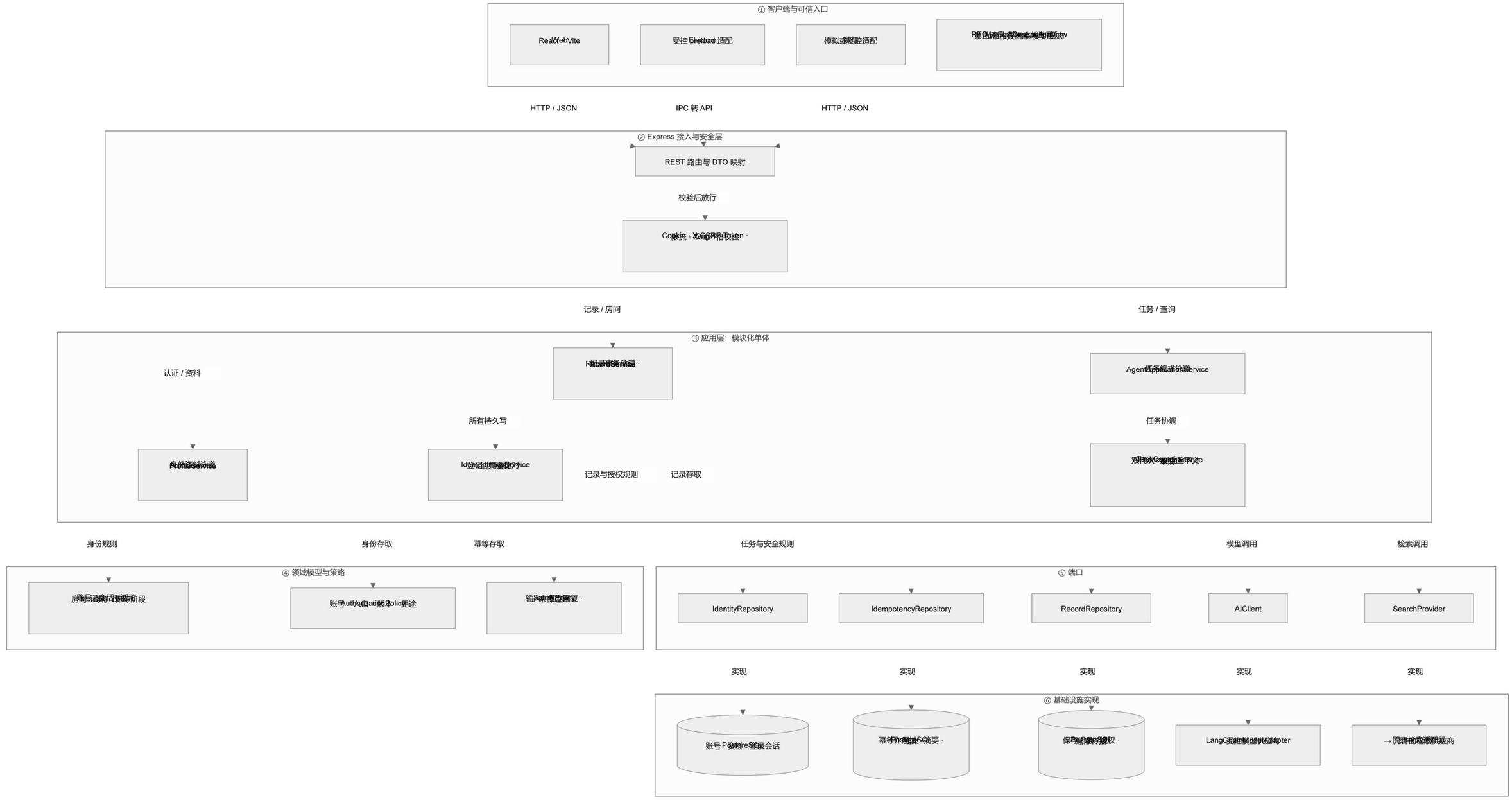
采用单实例模块化单体，利用现有 JavaScript 原型降低前后端转换成本。页面不直接连接数据库或供应商；接入层建立可信身份，应用服务执行用途授权，领域对象管理状态，仓储与适配端口隔离技术细节。REQ14 独立端侧旁路不流入通用业务状态。

层次	已批准方向
Web	React + Vite + JavaScript/JSX
服务端	Node.js + Express 模块化单体
校验	共享 Zod 严格 Schema
数据库	PostgreSQL + pg + SQL migration
Agent	LangChain JS；LangChainModelAdapter 实现 AIClient
入口	Web 首发；Electron 先验证；微信适配/模拟

2.2 系统体系结构

图中分层箭头表示调用与数据流方向；数据库、模型和搜索仅接受各自端口的受限调用，客户端不是可信归属来源。

图 2-1 系统体系结构



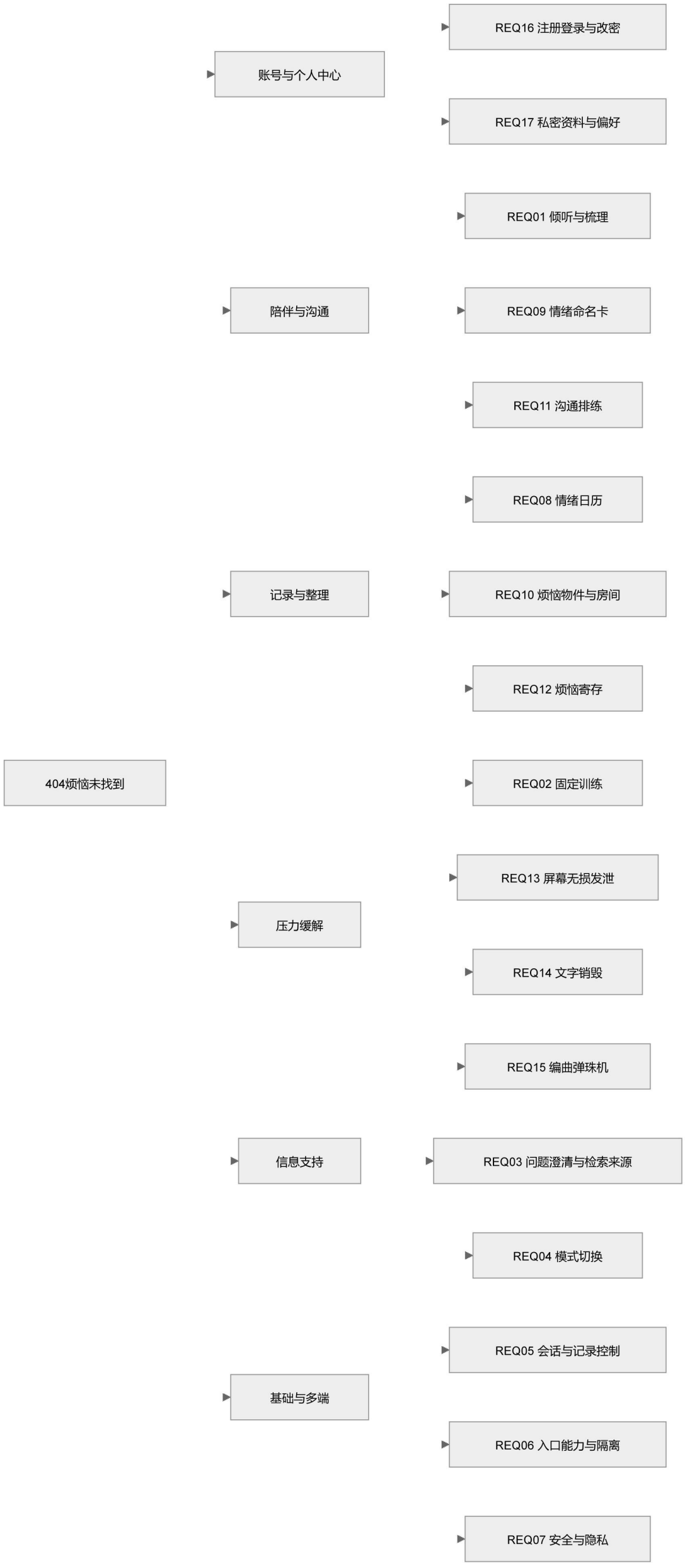
图源：仓库固定提交 fe60c90c1ed3；原始模型完整呈现。

3 功能模块层次设计

3.1 功能层次

以下层次仅按仓库六模块及需求表整理，不新增业务功能。一级为系统，二级为六模块，三级为现有需求。

图 3-1 功能模块层次图



图源：仓库固定提交 fe60c90c1ed3；原始模型完整呈现。

3.2 模块职责与输入输出

模块 / 需求	页面职责	必须呈现的控制与边界
账号与个人中心：REQ16、REQ17	注册、登录、改密、个人资料、本人内容入口、偏好	注册不自动登录；改密后重新登录；过期与读取失败分别显示；本人当前入口记录不公开
陪伴与沟通：REQ01、REQ09、REQ11	倾听 / 梳理、情绪词选择、AI 对话排练与认可表达	未选需要不擅自路由；暂停、重来、结束可用；排练仅整理本人本轮选中表达
记录与整理：REQ08、REQ10、REQ12	日历、烦恼物件与房间、寄存所	日历允许同日多条且只记不分析；放旁边不调用 AI；寄存到期不自动展开正文
压力缓解：REQ02、REQ13、REQ14、REQ15	四类基础训练、敲击回弹、独立文字销毁、编曲弹珠机	未开始不推进；暂停、继续、静音、重置、退出各有清理；文字销毁正文不进业务链
信息支持：REQ03	问题澄清、检索状态、摘要、对应来源与时间	无资料 EMPTY 与执行 failed 分开；来源冲突、过期和部分成功明确显示
基础与多端：REQ04、REQ05、REQ06、REQ07	模式切换、主动保存、记录查看 / 清除、入口能力、权限提示	内容携带需选择；保存、分析、跨端共享分别授权；按账号与可信入口隔离

首页承担六模块入口、当前身份与入口状态、主动保存内容入口及隐私说明。游客可先体验允许的临时功能；选情绪、登录或进入页面都不自动新增历史，不展示虚构打卡天数、心理评分或使用成绩。

3.3 前端分层与状态归属

层次	主要职责	依赖约束
页面与公共 UI	表单、来源卡片、加载 / 空 / 错误 / 权限视图、确认弹窗和键盘操作	调用功能控制器；不在视图事件中散落重试、数据库或音频释放逻辑
状态管理	身份、当前业务会话、任务、当前账号与入口的记录内存缓存、页面临时输入	不把所有功能正文汇入一个通用 Context；禁止自动读其他入口历史
接口适配	同源 /api、共享 Zod 校验、CSRF、状态映射、幂等与轮询	不接受客户端自报可信 ownerId / entry，不持有或读取 HttpOnly Cookie 原文

层次	主要职责	依赖约束
任务协调	捕获身份与双代次，登记取消句柄，过滤迟到结果	服务接受取消后不得再读取旧结果；本地 Abort 不等于服务停止
端侧互动	固定训练、敲击画布、弹珠物理、音频与动画	碰撞、音符和敲击不逐步上传；统一暂停与资源释放
Electron 适配	受控 preload 白名单与窗口生命周期	主进程校验窗口和参数；渲染层无 Node、通用执行或文件读写能力
独立销毁入口	私有输入与 SHRED / BURN / BLACK_HOLE 效果	独立 React 根和本地资源，不装配业务状态、API 客户端、持久化或遥测 SDK

组件依赖与数据隔离见 02 号文档，具体触发条件和清理动作见 03 号文档。

状态与数据归属

状态	保存位置 / 寿命	失效或清理条件
当前身份与 CSRF	内存；身份由安全 Cookie 与服务端会话确定	登录、退出、改密、401、换账号时失效旧请求、旧授权和缓存
业务会话与选中消息	内存；sessionId、activityId、双代次与当前消息	END、过期、身份变化清空；服务重启后重新开始，不自动重发正文
异步任务	内存；requestId、代次快照、AbortController、轮询句柄	终态停轮询；暂停、重来、切换、撤销先失效结果接收资格
已保存记录的客户端缓存	当前身份、可信入口与资源范围内的内存	换身份 / 入口全清；清除成功后失效详情、列表、上下文选择和关联
普通页面草稿	当前功能的临时内存	保存失败可保留当前身份编辑；身份变化清空；登录前如选择保留游客草稿，登录后仍需重新主动提交
设备偏好	独立非正文配置，可本地保存	仅静音、音量、减少动态效果等；不混入私密记录、正文或账号令牌
REQ14 原文与效果缓存	独立视图私有内存、DOM、粒子 / 纹理	完成、跳过、异常、切页、关闭均清空；不带账号、不恢复、不统计销毁内容或次数

持久化记录由应用服务写入 PostgreSQL。前端 API 缓存仅内存；Service Worker、CDN 和浏览器持久缓存不保存私密 API 正文。日历保存不代表分析许可；物件显示不代表正文留存许可；登录不代表跨端共享。

3.4 多入口能力边界

HTTP 能力接口为 GET /api/capabilities，返回 {entry,features:[{reqId,status,reason?,fallback?}]}。实际 status 仅为 AVAILABLE/SIMULATED/UNAVAILABLE：分别表示已验证可用、模拟、不可用。“跳转 / 降级”是界面处理方式，不新增服务枚举。

入口由受控接入适配与会话绑定确定。客户端不能用 entry 参数、X-Entry、User-Agent 或 Origin 自报可信平台。当前优先开放 WEB；DESKTOP、WECHAT 在身份与入口绑定完成前保持模拟或不可用。前端隐藏按钮不能替代服务端权限检查。

业务能力矩阵

需求 / 功能	Web 设计目标	Electron 桌宠设计目标	微信设计边界	不支持时的跳转 / 降级
REQ16～17 账号与个人中心	支持完整页面、本人资料及私密内容入口	原生窗口与可信 DESKTOP 认证完成后接入	取决于接入形式与授权；聊天中不收密码，不按昵称绑定	跳转受控 Web 登录 / 个人中心，明确进入 WEB 范围
REQ01 陪伴交流	支持倾听 / 梳理、临时对话及主动保存	支持目标为快捷面板或完整页	可按实际权限适配文字；未接入标模拟	展示能力说明或打开完整 Web 页，不自动携带聊天正文
REQ09 情绪命名卡	支持选词及 LISTEN / ORGANIZE / SEARCH 分流	简化选词面板或完整页	有实际适配时提供文本选择，否则跳转	未选 need 不路由；选词不自动保存
REQ11 平行宇宙排练	支持设置、暂停 / 继续 / 重来、选择表达与预览	快捷唤起完整排练页	文本适配或跳转，不能省略模拟与暂停边界	无法实现状态控制时打开完整页，不伪称聊天适配完整
REQ08 情绪与事件日历	支持同日多条、详情、编辑和清除	面板或完整页；数据仍在 DESKTOP 范围	简化查看 / 跳转须按实际身份支持	当前入口无数据时说明入口隔离，不自动读 WEB 记录

需求 / 功能	Web 设计目标	Electron 桌宠设计目标	微信设计边界	不支持时的跳转 / 降级
REQ10 物件与房间	支持临时形状、房间画布与主动保存	目标为桌宠房间与物件显示	不承诺原生图形房间，可提供跳转	Web 画布；缺渲染时可用外观选择列表，放旁边仍零 AI
REQ12 烦恼寄存所	支持寄存、状态、主动取出 / 延期 / 清除	包裹外观与面板入口，不自动展开正文	以实际适配提供文字状态或跳转	到期仅显示可取出；无权限不提供正文
REQ02 固定小训练	支持本地引导、暂停、继续、重置、退出	轻量面板；收起 / 隐藏自动暂停	可适配固定文本步骤，不能宣称等同画布互动	静态引导 / Web 页；音频失败可静音，退出始终可用
REQ03 信息查询	支持检索状态、摘要与来源、主动保存	快捷查询或完整结果页	可按权限展示带来源文本或跳转	来源过期 / 冲突如实提示；服务失败不显示无结果
REQ13 屏幕无损发泄	支持本产品画布内效果；不支持覆盖其他应用	CO3 验证后才允许原生桌面浮层	不支持聊天窗口内全桌面互动	降级为 Web 画布或说明页，明确区域限制
REQ14 文字销毁	独立本地页面，正文不保存、不上传	独立端侧视图，不挂通用聊天 / 遥测	聊天中不接收待销毁正文；仅提供无正文入口	跳转独立本地打包页面；环境不能保证隔离时不可用
REQ15 编曲弹珠机	支持本地物理画布与用户手势启用音频	打开完整画布或受控面板	不承诺原生聊天物理与音乐，可跳转	简化效果 / 静音并说明；无法稳定运行则停止并允许退出
REQ04～05 模式、保存与清除	支持显式切换、用途许可、版本化保存及确认清除	同样执行控制与隔离	仅在实际接入控制流程后开放	无批量清除接口，不展示一键全清已接通
REQ06～07 隔离与安全	WEB 范围；身份、用途、归属校验	DESKTOP 范围，必须有可信接入	WECHAT 范围，适配前不可自报启用	跨入口跳转仅带白名单页面键；不自动共享记录或正文

同账号不代表共享不同入口的业务会话或记录。桌宠跳 Web 须说明目标为 WEB 范围；默认不带正文、凭据、私密记录 ID 或未经选择的上下文。销毁链接始终不带正文。

4 详细设计与设计类图

4.1 表达规则与类职责

本章六张图均来自仓库完整设计类图 V1.2 的原始 Mermaid 代码，属性、方法、关系和多重性不作结构修改。同名类在各图中表示同一元素；泛化指向父类，实现指向接口，组合菱形位于整体，聚合不自动定义删除规则。

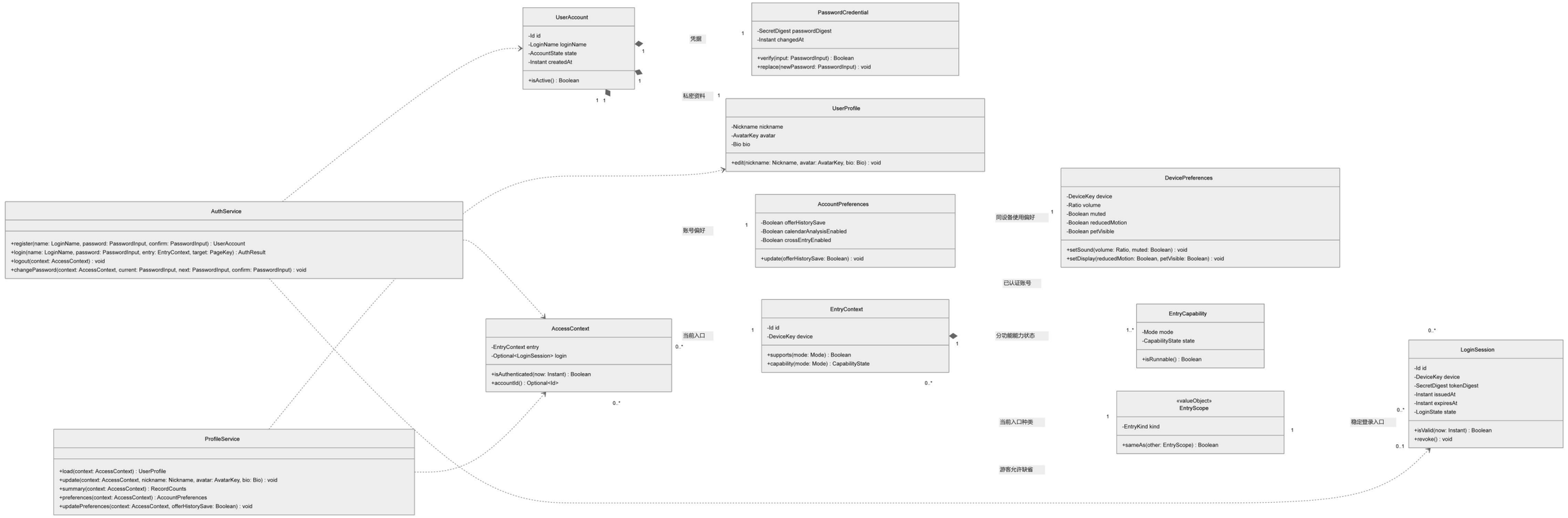
表达	UML 语义	本模型用法
+ / - / #	public / private / protected	状态封装在属性中，通过公开方法改变
A <|-- B	泛化：B 继承 A	活动子类、持久化记录子类
I <|.. C	实现：C 实现 I	可停止活动、仓储和端侧算法接口
A ..> B	依赖	临时参数、调用或使用 B
A "1" -- "0..*" B	关联	一对多；无箭头表示本图不限定导航性
A "0..1" o-- "0..*" B	共享聚合	房间组织物件；移出房间不删除物件
A "1" *-- "0..*" B	组合	部件只属于一个整体，生命周期由整体管理

多重性标在关联两端；继承、实现、依赖没有实例数量语义，因此不标多重性。菱形位于整体端，空心三角指向父类或接口。<<abstract>>、<<interface>>、<<enumeration>>为分类标记。

属性采用 -类型 属性名；方法采用 +方法名(参数名: 类型) 返回类型，适配 Mermaid 类图语法。结构化解释等价于 UML 的 -属性名: 类型、+方法名(参数名: 类型): 返回类型。

4.2 账号与入口身份

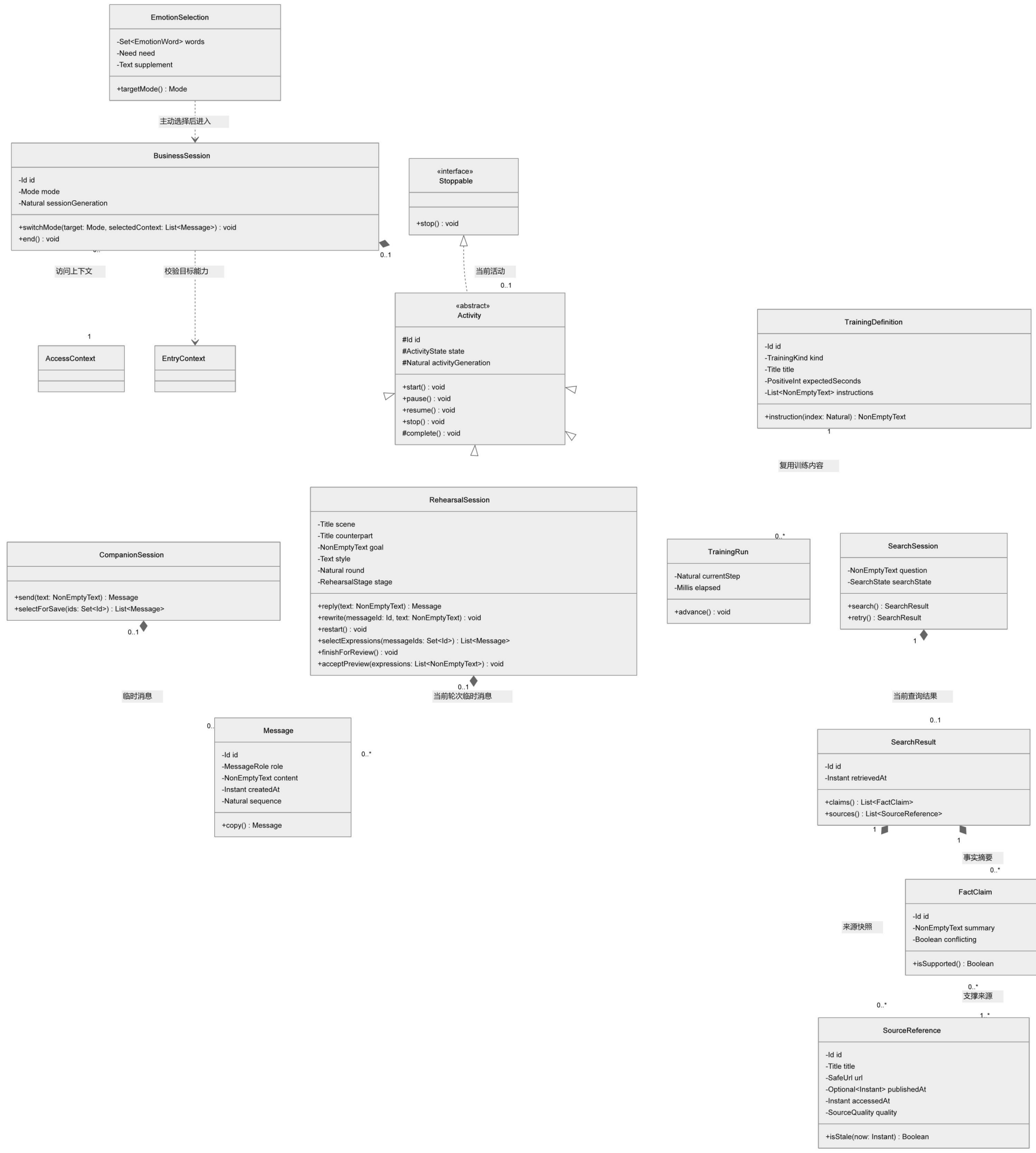
图 4-1 账号与入口身份



图源：仓库固定提交 fe60c90c1ed3；原始模型完整呈现。

4.3 临时业务活动

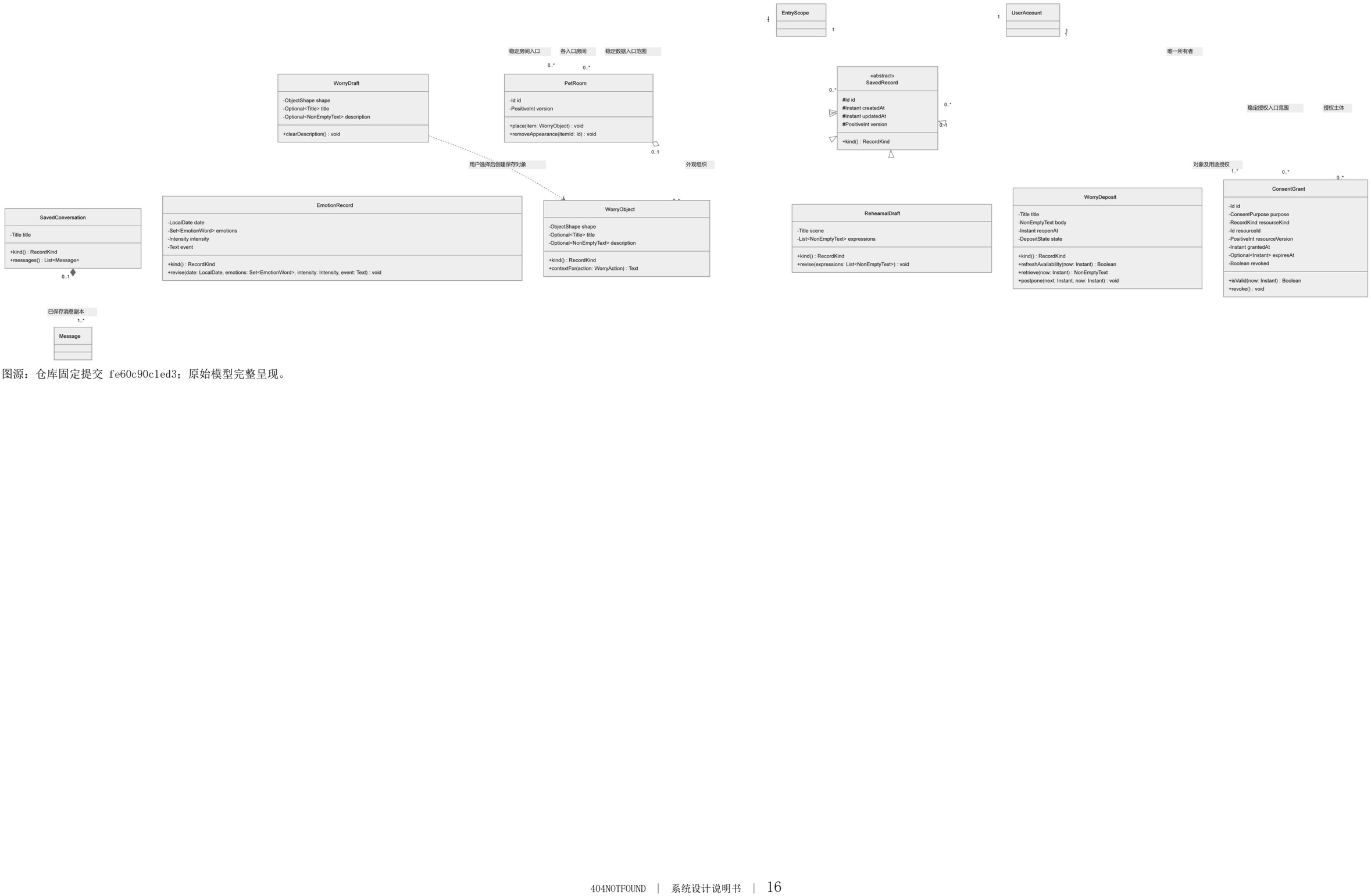
图 4-2 临时业务活动



图源：仓库固定提交 fe60c90c1ed3；原始模型完整呈现。

4.4 保存记录与用途授权

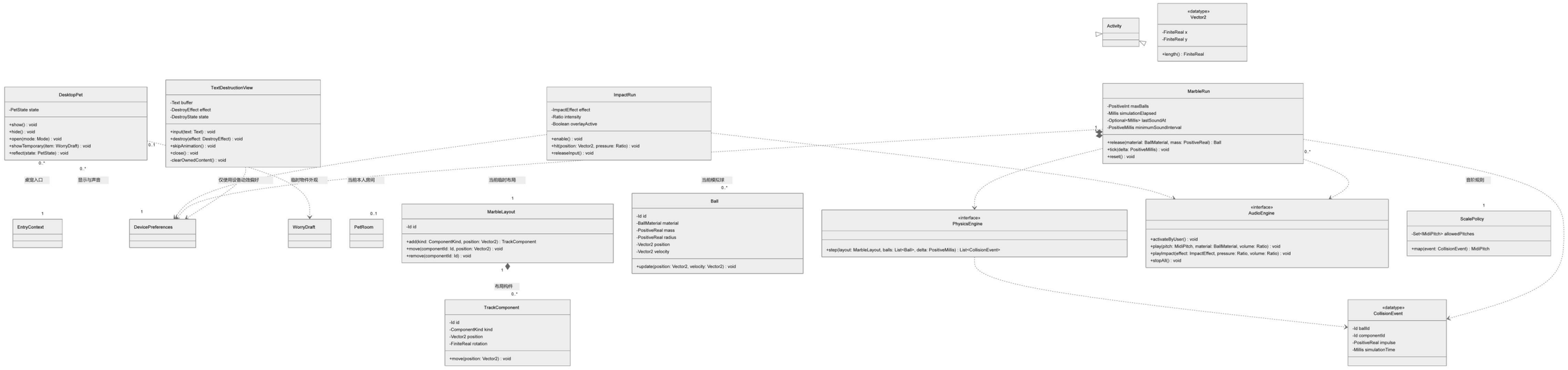
图 4-3 保存记录与用途授权



图源：仓库固定提交 `fe60c90c1ed3`；原始模型完整呈现。

4.5 端侧互动与物理音频

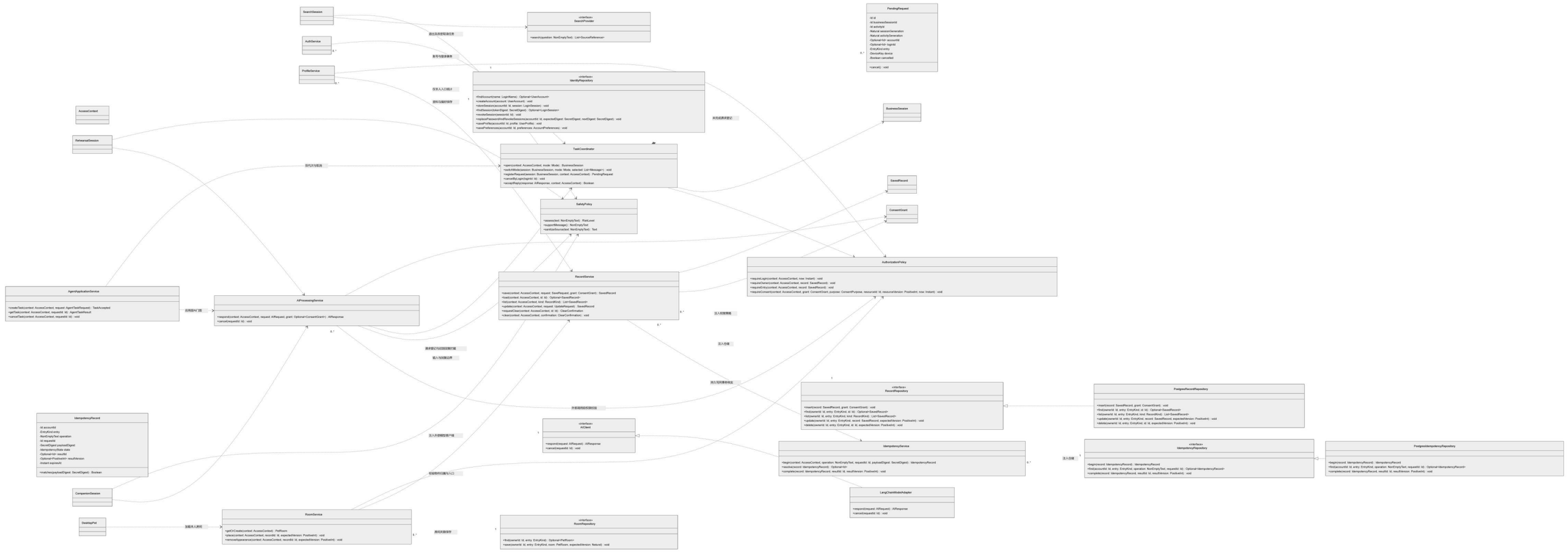
图 4-4 端侧互动与物理音频



图源：仓库固定提交 fe60c90c1ed3；原始模型完整呈现。

4.6 应用服务与仓储适配

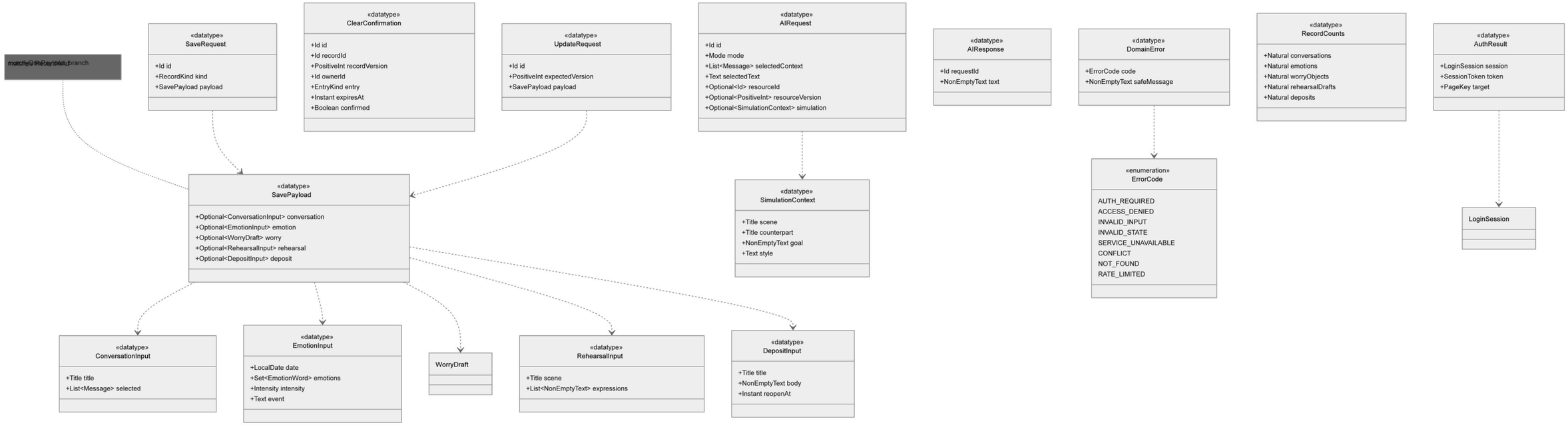
图 4-5 应用服务与仓储适配



图源：仓库固定提交 `fe60c90c1ed3`；原始模型完整呈现。

4.7 接口数据类型

图 4-6 接口数据类型



图源：仓库固定提交 `fe60c90c1ed3`；原始模型完整呈现。

4.8 类型约束与聚合不变量

图中每个属性均使用下列基础类型、约束类型、枚举或模型类类型；约束类型是 UML 数据类型，不要求编程语言原生支持。所有未带 Optional 的属性非空，集合元素也非空。关联端的对象数量由多重性决定。

类型	底层类型与取值范围
Id	UUID；合法且非全零；实体 ID 在对应实体集合中唯一
Instant	UTC 时间戳；合法可表示时刻；业务前后顺序另列不变量
LocalDate	合法公历日期；按用户所在时区解释，不按 UTC 截断日期
Boolean	true 或 false
Natural / PositiveInt	Integer；分别为 ⩾0 / ⩾1
Ratio	Real；有限数，0～1
PositiveReal	Real；有限数且 >0
FiniteReal	Real；有限数，排除 NaN、正负无穷
Intensity	Integer；不是诊断评分
LoginName	String；建议 3～64 字符；标准化后账号集合内唯一
Nickname	String；建议 1～32 字符；允许重名
Bio	String；建议 0～200 字符
Title	String；建议 1～80 字符；去除首尾空白后非空
Text	String；建议 0～4000 字符；字段允许为空时使用此类型
NonEmptyText	String；建议 1～4000 字符；去除首尾空白后非空
EmotionWord	String；建议 1～20 字符，支持预设词和用户补充词
PasswordInput	临时敏感 String；12～128 Unicode 码点；不作为持久化属性、不进入日志或 AI 上下文
SecretDigest	非空带算法/参数的不可逆凭据摘要；不得为明文密码或原始令牌
AvatarKey	预设头像目录中的有效键；首轮不建模自定义文件上传

类型	底层类型与取值范围
DeviceKey	本产品生成的非空设备实例标识；不包含硬件身份数据
SafeUrl	合法 HTTP/HTTPS URL；展示、请求前按实际用途校验；不执行 URL 或页面中的指令
PageKey	产品允许的内部页面键；不接受任意外部跳转地址
MidiPitch	Integer；0～127；实际可播放值还必须属于当前音阶集合
Millis	Integer；≥0 毫秒
PositiveMillis	Integer；>0 毫秒
Optional~T~	T 或缺省，数量 0..1；缺省不等于空字符串
List~T~ / Set~T~	0..* 个 T；Set 元素唯一；额外下限由业务不变量限定
模型类类型	符合相应类的属性、状态和不变量的对象；引用不得越权

字段长度、密码规则、强度标尺和运行资源上限均是建议，不是已冻结需求。接口边界也执行验证，不能只靠页面控件限制。

枚举

类型	完整取值
EntryKind	WEB、DESKTOP、WECHAT
CapabilityState	AVAILABLE、SIMULATED、UNAVAILABLE
AccountState	ACTIVE、LOCKED；锁定是认证保护状态，不代表新增账号管理页面
LoginState	VALID、EXPIRED、REVOKED
ActivityState	READY、RUNNING、PAUSED、COMPLETED、STOPPED
RehearsalStage	SETUP、READY、RUNNING、PAUSED、REVIEWING、PREVIEW、SAVED、ENDED；应用阶段映射，不替代 ActivityState
Mode	LISTEN、ORGANIZE、SEARCH、REHEARSE、TRAIN、CALENDAR、ROOM、LOCKER、IMPACT、MARBLE
Need	LISTEN、ORGANIZE、SEARCH
MessageRole	USER、ASSISTANT；不把内部系统提示作为用户可保存消息

类型	完整取值
RecordKind	CONVERSATION、EMOTION、WORRY_OBJECT、REHEARSAL_DRAFT、DEPOSIT、QUERY
ConsentPurpose	SAVE、AI_PROCESS、SEARCH_PROCESS、ANALYZE、CROSS_ENTRY；后两者首轮默认不开放
ObjectShape	TANGLE、STONE、NOTE
IdempotencyState	IN_PROGRESS、COMPLETED、FAILED；只保存非正文元数据
WorryAction	DECOMPOSE、PUT_ASIDE、SMALL_STEP
DepositState	STORED、AVAILABLE、RETRIEVED；删除成功后不存在对象，不用 DELETED 代替实际清除
TrainingKind	BREATHING、FIVE_SENSES、PAUSE_ORGANIZE、TASK_SPLIT
SearchState	READY、SEARCHING、SUCCESS、EMPTY、FAILED；时效和冲突作为来源/断言质量标记
SourceQuality	CURRENT、STALE、UNKNOWN
ImpactEffect	CRACK、SPLASH、DENT
DestroyEffect	SHRED、BURN、BLACK_HOLE
DestroyState	EMPTY、EDITING、ANIMATING、CLEARED
ComponentKind	RAIL、SPRINGBOARD、CHIME、WHEEL
BallMaterial	WOOD、GLASS、METAL
PetState	IDLE、LISTENING、PACKAGE、RELAXING；只表达功能状态
RiskLevel	NORMAL、SUPPORT_NEEDED；不作为临床诊断标签

1. RecordService 是受保护业务记录的入口；调用仓储前校验有效登录、所有者与 EntryKind，保存/AI 用途还需对应授权。仓储接口再次以 ownerId+entry 限定查询和清除范围；不得按 id 单独查询后直接泄露数据。

2. PostgresRecordRepository 是本轮确定的服务端 PostgreSQL 仓储实现，负责参数化查询与事务；它实现 RecordRepository，后续基础设施仍可经端口替换，但不得自动开启跨入口同步。

3. 插入记录与 SAVE 授权、更新记录、删除记录及其消息副本需事务保证。清除后不得在活动上下文、缓存或后续 AI 请求中继续使用对应数据；失败时不返回成功。

4. 持久化仅保存主动提交的记录。临时聊天的外部 AI 处理按明确告知与选择执行；不要求游客建立持久化授权表。对已保存物件的 AI 处理必须有对应对象的单独 AI_PROCESS 授权。

5. AIProcessingService 在外部调用前执行用途和内容范围校验；AIClient 只负责模型传输，不把业务权限判断推给底层接口。PendingRequest 捕获请求、会话/活动 ID、两个 generation、账号/登录 ID、入口与设备；回复必须全部匹配且请求未取消，并重新验证登录有效性。当前模型不指定 AI/检索厂商，不把网页内容视为可信指令。

6. SafetyPolicy 遇明显危机表达停止常规引导，输出经产品审核的现实支持提示；不称为自动救援，不生成诊断结论。本文没有提供真实求助号码或新增外部发送动作。

7. TaskCoordinator 取消与账号相关的异步请求和活动。登录不会把游客临时输入自动迁移为已保存数据；用户必须在身份确认后重新主动提交保存。

8. IdentityRepository.createAccount 原子创建账号及其三个部件并校验登录名唯一；replacePasswordAndRevokeSessions 原子校验旧摘要未并发改变、更新摘要并撤销全部旧会话。ProfileService 保存资料/偏好必须经该仓储提交，RoomService 通过 RoomRepository 持久化房间外观关联；与物件删除相关的变更必须共享事务协调，不允许悬空引用。ClearConfirmation 是拟开发产品中的记录清除确认，不是删除本工作区文件的授权。本次只新增修订版交付文件并保留旧版，没有删除已有项目文件。

关系	多重性/类型	工程含义
账号→资料、凭据、账号偏好	各 1 *-- 1	专属部件；不提供新增账号注销流程
账号→登录会话	1 -- 0..*	多设备会话，可过期撤销；与业务任务分开
访问上下文→登录会话	0..* -- 0..1	游客无登录；多个请求上下文可引用同一有效登录
业务会话→当前活动	0..1 *-- 0..1	切换时停止并释放旧活动，避免并发推进旧模式
活动→消息/查询结果	组合	临时部件随活动结束清理，不自动持久化
摘要→来源	0..* -- 1..*	每个事实摘要可追溯，多摘要复用来源
账号→已保存记录	1 -- 0..*	退出后记录仍存在；所有者不可更改

关系	多重性/类型	工程含义
已保存记录→授权	0..1 -- 1..*	分对象分用途；授权未提交时允许无已保存记录
房间→物件	0..1 o-- 0..*	外观组织不拥有正文生命周期
布局→构件，运行→小球	组合	明确临时模拟对象的唯一整体和退出回收
具体活动→Activity	继承	复用状态、generation 与停止协议
Activity→Stoppable	实现	统一取消能力，而非“活动是一种仓储”之类错误继承
本地仓储→仓储接口	实现	隔离存储技术决策
服务→AI/查询/权限等	依赖或注入关联	临时使用标依赖；长期持有注入对象标关联

共享聚合在 UML 中不自动定义删除规则，所以房间解除关联、物件正文清除分别在业务契约中约束。组合仅用于专属部件，不能用组合暗示“账号一退出就删除全部历史”。

5 接口设计

5.1 接口目录与调用契约

以下按仓库接口目录和 09 号规范组织。目录有 32 个唯一方法路径，日历筛选复用记录列表。身份与入口从可信接入及登录会话推导；所有写请求验证 X-CSRF-Token 与 Origin。完整请求字段在本章给出，不要求读者另找外部源稿才能理解。

日历 GET /api/records?kind=EMOTION&from=...&to=... 是 GET /api/records 的筛选用法，不另计一个端点。

认证与个人中心 10

序号	方法	路径	用途
1	GET	/api/auth/context	建立或读取匿名/登录上下文，返回 CSRF token
2	POST	/api/auth/register	注册，不自动登录
3	POST	/api/auth/login	登录并轮换会话
4	POST	/api/auth/logout	撤销当前会话、清 Cookie、取消相关任务

序号	方法	路径	用途
5	POST	/api/auth/change-password	改密并撤销全部旧会话与任务
6	GET	/api/profile	读取本人私密资料
7	PATCH	/api/profile	按版本更新资料
8	GET	/api/profile/summary	读取当前入口分类计数
9	GET	/api/preferences	读取账号提示偏好
10	PATCH	/api/preferences	按版本更新提示偏好

会话与用途授权 5

序号	方法	路径	用途
11	POST	/api/sessions	创建临时业务会话与初始活动
12	POST	/api/sessions/:id/switch	切换模式并更新双代次
13	POST	/api/sessions/:id/actions	PAUSE、RESUME、RESTART、FINISH_REHEARSAL、END
14	POST	/api/consents	创建逐用途、逐载荷许可
15	POST	/api/consents/:id/revoke	撤销许可并取消相关任务

Agent 与检索 6

序号	方法	路径	用途
16	POST	/api/agent/tasks	受理 LISTEN、ORGANIZE、REHEARSE 任务
17	GET	/api/agent/tasks/:requestId	读取 Agent 任务状态与有效结果
18	POST	/api/agent/tasks/:requestId/cancel	幂等取消 Agent 任务
19	POST	/api/search/tasks	受理 SEARCH 任务

序号	方法	路径	用途
20	GET	/api/search/tasks/:requestId	读取检索状态、事实与来源
21	POST	/api/search/tasks/:requestId/cancel	幂等取消检索任务

记录与房间 8

序号	方法	路径	用途
22	POST	/api/records	持 SAVE 许可主动创建记录
23	GET	/api/records	分页读取本人当前入口记录；日历为 query 筛选
24	GET	/api/records/:id	读取记录详情
25	PATCH	/api/records/:id	按版本和 SAVE 许可更新允许编辑的记录
26	POST	/api/records/:id/clear-confirmations	签发两分钟单次清除确认
27	POST	/api/records/:id/clear	事务清除记录及关联
28	GET	/api/room	读取本人当前入口房间
29	PUT	/api/room	按版本保存最多 30 个物件的房间布局

寄存与能力 3

序号	方法	路径	用途
30	POST	/api/deposits/:id/retrieve	到期后本人主动取回正文
31	POST	/api/deposits/:id/postpone	按版本延期
32	GET	/api/capabilities	读取可信入口能力状态

5.2 全局协议与技术约束

5.2.1 调用与存储

Web/桌宠适配→Express 应用 API→应用服务→受限 Agent/LangChain 或 pg 仓储。JavaScript ESM；前后端复用 shared/contracts/*.js 中的 Zod 规则，服务端采用严格对象 Schema 拒绝未知字段。校验成功仅表示结构合法，仍须检查身份、归属、入口、用途及版本。SQL 参数使用 pg 参数化查询；事务内操作使用同一连接，禁止用连接池的多次随机连接拼接事务。

本规范路径统一以/api 开头；前端同源访问。第一阶段实际开放 WEB 适配，DESKTOP/WECHAT 在相应身份与入口绑定验证前标 SIMULATED/UNAVAILABLE，不能通过 entry 请求字段或 X-Entry 头启用。入口由受控接入适配及其签发会话确定，服务检查会话绑定，不把 User-Agent、Origin 或设备自报值当成可信平台证明。Electron 验证阶段只使用合成数据和本地演示。

登录会话、账号、资料、主动保存记录存 PostgreSQL。业务会话、当前消息、AI 任务、临时授权默认仅进程内存，服务重启后失效，客户端显示“临时会话已失效，请重新开始”，不得自动重发正文。当前采用单实例应用服务；扩容前另行设计任务归属、取消广播和共享限额。

5.2.2 通用类型与限制

类型/参数	本轮采用的限制	校验与行为
id / requestId	合法非全零 UUID	requestId 为客户端操作幂等标识，业务实体 ID 由服务端分配；知道 ID 不等于有访问权
loginName	NFKC 后 3～64 个 ASCII 字母/数字/下划线，统一小写索引	页面使用同一标准化规则；昵称与登录标识分开
password / newPassword	12～128 个 Unicode 码点	不 trim、不做 Unicode 规范化；注册/改密使用此限制；登录只校验非空及上限，账户验证后续如支持旧密码须单列迁移策略
nickname / bio / title	1～32 / 0～200 / 1～80 码点	文本字段可 trim；标题不能全空；bio 纯文本，不接受 HTML

类型/参数	本轮采用的限制	校验与行为
selectedText / event / body	每字段最多 4000 码点	selectedText 可空仅限还有有效选定上下文；寄存 body 非空；计数用 Array.from(text).length 的码点语义
selectedContextIds	0～20 个当前任务消息 ID，不重复	消息+选定正文/物件/场景合计最多 12000 码点；包括服务端展开内容；凭据/system 提示不计作用户字段但仍计入模型窗口预算
expectedVersion	正整数	更新/清除与当前版本一致才提交；生成代次用非负整数，两个字段不得混用
emotionWords / intensity	1～5 个不重复情绪词，每词 1～20 码点；强度整数 1～5	是记录标尺，不作诊断评分
date / instant	YYYY-MM-DD / 带偏移 ISO8601 时刻	严格校验真实日期；时刻存 UTC，用户时区单独指定；不按浏览器 UTC 日期替代用户日历日
分页	limit 默认 20，最大 50；cursor 为不透明游标	固定按 createdAt 与 id 排序；游标绑定账号、入口、类型及过滤条件，禁止跨范围复用
HTTP 正文	application/json，最大 128 KiB	超出 413；请求 URL 只含非正文参数，问题/聊天不放 URL；禁止上传任意文件/自定义头像

4000 码点是字段限制，不能替代模型 token 预算。模型适配层还须检查实际模型窗口，必要时返回参数错误并请用户缩小选择，不擅自裁掉用户认可表达或跨入口找补上下文。所有数字是初始设计配置，非实测性能。

5.2.3 鉴权、错误与缓存

会话 Cookie：__Host-session，HttpOnly、Secure、SameSite=Lax、Path=/、不设置 Domain；仅保存原始随机凭据。服务端保存其摘要。游客建立短时匿名上下文，登录后轮换，游客临时内容不自动迁移。

GET /api/auth/context 创建/读取匿名或登录上下文并返回 CSRF token，响应 no-store；不能返回 Cookie 原始凭据。所有 POST/PUT/PATCH/DELETE 都校验会话绑定的

CSRF token 和允许的 Origin；登出/登录后刷新 CSRF token。缺少有效登录返回 401，游客允许的路径仍须有效匿名上下文。

成功响应统一{data, meta:{requestId}}，204 没有正文；错误统一{error:{code,message,fields?,retryAfterSeconds?},meta:{requestId}}。字段错误只含字段路径和规则，不回显密码、Cookie、选定正文、模型提示或原始堆栈。

HTTP	业务 code/含义	适用处理
400	INVALID_INPUT	格式、字段、范围错误；不调用模型/不提交 DB
401	AUTH_REQUIRED	登录缺失/过期，隐藏私密视图；不把正文放登录跳转
403	ACCESS_DENIED	CSRF、用途或明确可告知的权限失败
404	NOT_FOUND	对象不存在或属于他人/其他入口时统一安全响应，服务内部区分原因但不泄露对象存在性
409	CONFLICT / INVALID_STATE	版本不匹配、幂等键不同载荷，或当前状态不允许操作
413	INVALID_INPUT	HTTP 正文超上限
429	RATE_LIMITED	带 Retry-After；不得无限自动重试
503	SERVICE_UNAVAILABLE	DB、供应商或服务不可用；不能以空历史代替

NOT_FOUND/RATE_LIMITED 是对旧六项 DomainError 枚举的本轮扩展，需同步 UML。取消/超时不再增加 CANCELLED/TIMEOUT 业务错误枚举：已登记任务使用 status=cancelled 或 status=failed,failureReason=TIMEOUT，GET 正常返回状态；尚未登记就失败的请求返回上述 HTTP 错误。

全部私密及临时任务响应 Cache-Control: no-store；前端查询缓存仅内存，切换身份/入口/结束时清空；Service Worker 和 CDN 不缓存 API 正文。禁记请求/响应正文、Cookie、密码及 SQL 参数；只观测脱敏操作 ID、状态、耗时、用量。SQL 错误不给客户端回显。

5.2.4 幂等、时限与资源限制

创建/保存/业务动作在 body 带 requestId；同身份+入口+操作+requestId+同规范化载荷重试返回原操作结果，不重新执行；载荷不同 409。限速先于昂贵哈希/外部调用执行。AI 任务幂等元数据仅内存，进程重启不承诺跨重启幂等。持久记录操作在同一 DB 事务记录幂等元数据和版本，元数据仅含作用域、载荷摘要、结果 ID/版本与状态，不重复保存正文；保留 24 小时，超过后返回现有记录真实状态，不能复活已清除正文。登录不缓存含令牌响应，退出/改密靠会话撤销与事务保证。

普通 API 总时限 5 秒、DB 语句初始 2 秒、事务初始 3 秒；超时必须取消/回滚或等待已提交事实核实，不以客户端超时断言写入失败，客户端用同 requestId 核实后显示实际状态。AI/检索总时限 30 秒，模型 maxRetries=0、工具最多 3 轮；先输入/授权/限额校验再登记。每个登录账号跨会话最多 1 个运行或排队的外部任务，游客按匿名上下文与 IP 限额；单实例最多 4 个并发外部任务、等待队列最多 8 个；超出 429，排队计入 30 秒。每身份外部任务创建最多 10 次/分钟（游客另按 IP10 次/分钟），初始每日成功受理任务上限登录 100 次、游客 20 次，服务侧费用硬上限单独配置；拒绝不计费重试循环。轮询每任务每客户端 1 秒一次、最多 1 个在途请求，服务端每身份轮询总量最多 120 次/分钟；结束即停。取消和退出不受 AI 创建额度阻断，仍做防滥用限频。

5.3 共享会话、授权和 Agent 契约

5.3.1 临时业务会话

方法/路径	输入	返回与副作用	归属/限制
POST /api/sessions	{requestId, mode}；mode=LISTEN/ORGANIZE/REHEARSE/SEARCH	201 {sessionId,activityId,sessionGeneration:0,activityGeneration:0,mode,state:ready}	游客/登录均可；服务端分配 ID，仅当前身份入口可用；无正文持久化
POST /api/sessions/:id/switch	{requestId,targetMode,expectedSessionGeneration,selectedContextIds}	200 新活动 ID 及双代次；先校验目标能力，再停止旧活动，按用户选择复制内容	跨模式复制不自动外发；新 AI 任务需新授权；不存在/越权 404，代次不符 409

方法/路径	输入	返回与副作用	归属/限制
POST /api/sessions/:id/actions	{requestId,action,expectedSessionGeneration,expectedActivityGeneration}；action=PAUSE/RESUME/RESTART/FINISH_REHEARSAL/END	200 当前 state 和双代次；PAUSE/RESTART/FINISH_REHEARSAL/END 失效原请求；RESUME 不重放旧请求	END 释放正文及临时授权；RESTART 建立新活动；FINISH_REHEARSAL 进入仅供选表达的 reviewing；本地训练/互动无需逐步请求服务器

无活动 30 分钟过期，业务会话绝对寿命 2 小时（初始配置），结束/过期立即清理正文；单条任务完成不等于业务会话结束。登录/换账号/改密撤销使旧身份相关业务会话失效。临时状态中允许同业务会话持有多条消息，单次上下文仍受 20 条/12000 码点限制。

5.3.2 用途授权

POST /api/consents：{requestId,purpose,sessionId?,activityId?,sessionGeneration?,activityGeneration?,operation,payload}。purpose 为 AI_PROCESS、SEARCH_PROCESS 或 SAVE；operation 限定任务生成、记录创建/更新等白名单。payload 采用对应操作的同一严格 Schema，不接收任意 messages/system；授权界面提交前明确展示外发或保存范围。服务在内存计算规范化载荷摘要，绑定身份、入口、双代次、记录 ID 及版本，返回 201 {consentId,purpose,expiresAt}。初始 5 分钟有效，执行时再校验；载荷或版本变化必须重新取得许可。AI/SEARCH 授权可供同一逻辑操作的幂等重试使用，不能用于另一任务。

临时正文仅授权计算时内存使用，授权元数据不含正文；游客授权不落库。SAVE 要求有效登录；保存时将必要授权元数据与记录同事务提交。POST /api/consents/:id/revoke 带 requestId，200 返回 revoked，取消相关在途任务并使未提交的保存许可失效；已保存记录不会因撤销许可隐式清除，用户另行确认清除。

5.3.3 Agent 任务 仅 LISTEN/ORGANIZE/REHEARSE

POST /api/agent/tasks 完整请求：

```
{
  "requestId": "2f74a372-2e54-4fe7-945a-a7992cf4a06b",
  "sessionId": "53763668-4b04-4e47-a477-2e35c74df1fd",
  "activityId": "8b45a7a2-651b-4d7e-9906-7e3c2bed45b2",
  "sessionGeneration": 0,
  "activityGeneration": 0,
```

```
  "mode": "LISTEN",
  "operation": "REPLY",
  "selectedText": "最近小组沟通有些困难，我想先说一说。",
  "selectedContextIds": [],
  "consentId": "791bf819-e50c-4d19-845b-a3e529614abb"
}
```


operation：REPLY、OBJECT_ORGANIZE、REHEARSAL_REPLY、REHEARSAL_SUMMARIZE；与 mode 严格对应。OBJECT_ORGANIZE 限 ORGANIZE，指定已保存物件时增加 resourceId/resourceVersion；未保存物件使用 objectDraft:{shape,title,description}，不得同时给两种来源。REHEARSE 必须给 simulation:{scene,counterpart,goal,style}（场景/对象为 Title、goal 为非空正文、style 为 Text）；整理时还需 recognizedMessageIds（当前轮次本人消息 ID，1～20 个）。REHEARSAL_REPLY/SUMMARIZE 均要求 REHEARSE；普通 REPLY 只限 LISTEN/ORGANIZE。以上展开的全部文本同受 12000 码点预算。

201 式创建不用于外部生成任务：受理返回 202 {requestId,status:pending,sessionId,activityId,sessionGeneration,activityGeneration}；客户端轮询 GET /api/agent/tasks/:requestId。pending/running/completed/cancelled/failed/expired 为任务状态；running 可内部映射等待/执行，不新增持久表。完成返回 200：


```
{
  "data": {
    "requestId": "2f74a372-2e54-4fe7-945a-a7992cf4a06b",
    "sessionId": "53763668-4b04-4e47-a477-2e35c74df1fd",
    "activityId": "8b45a7a2-651b-4d7e-9906-7e3c2bed45b2",
    "sessionGeneration": 0,
    "activityGeneration": 0,
    "status": "completed",
    "result": {"text": "可以先从最让你为难的那次沟通说起。", "userMessageId": "0eb60921-e60e-4877-bd07-ebcd6597a18b", "replyMessageId": "47451468-4a55-471f-b9fd-e055f4c17c11"}
  },
  "meta": {"requestId": "2f74a372-2e54-4fe7-945a-a7992cf4a06b"}
}
```


生成正文最大 4000 码点，供应商输出预算另按选定模型配置，结果非字符串、空白、截断或超限均进入失败，不盲目展示。POST /api/agent/tasks/:requestId/cancel 输入 {requestId:本次取消操作 ID}，200 返回目标任务 cancelled；已取消重复调用幂等，已完成仍可撤销可取结果并清理任务副本，不撤回已向用户展示的内容。取消服务接受后结果端点不再返回正文；底层未能终止也不得回填。

完成结果可在当前有效业务活动中临时取 5 分钟；之后状态 expired 且不含结果，当前会话消息在业务会话结束前可供用户选定保存。明确结束、暂停/重来、换模式、撤销、退

出/改密时按受影响代次立即禁止旧任务读取。失败返回 status:failed,failureReason:TIMEOUT/PROVIDER_UNAVAILABLE/OUTPUT_INVALID，不含供应商原始异常；手动重试用新 requestId 并重新核验授权与额度。

5.4 REQ01 陪伴交流

使用第 5.3 节临时会话、授权和 Agent 任务；mode=LISTEN/ORGANIZE、operation=REPLY。先明确用户希望倾听或整理，输入不明确不强制训练。只传当前有效活动选定消息，无自动读取历史；服务端分配消息 ID。未选保存不写聊天表。空输入且无有效上下文 400，活动已停止 409，未许可外发 403，任务故障按第 5.3.3 节显示失败。主责程群，API 李泉毅，UI 程杰。

5.5 REQ02 压力缓解小训练

训练定义是随包发布的审阅静态资源 training-definitions.json，每项有 id、title、steps、durationHint、contentVersion；不设置每一步 AI 接口。端侧 TrainingController.start(id)、pause()、resume()、stop()、reset()返回 {state,stepIndex,elapsedMs}；仅状态转换有效才推进，不适时立即停止。暂停不累计运行时长，页面隐藏可自动暂停，退出清除定时器。任务拆分如用户需要生成建议，另用 ORGANIZE+REPLY 并取得 AI 许可；没有模型不影响固定训练。程群内容/路由，程杰实现。

5.6 REQ03 信息查询

查询独立于旧 AIRequest 三种 mode：SEARCH 业务会话调用 POST /api/search/tasks，输入 {requestId,sessionId,activityId,sessionGeneration,activityGeneration,question,selectedContextIds,consentId}；question 为 NonEmptyText，需 SEARCH_PROCESS 许可，明确其中是否包含模型整理外发（使用模型时同时要求 AI_PROCESS 许可，通过另加 aiConsentId 引用）。受理 202，GET /api/search/tasks/:requestId 和 POST 同路径 /cancel 沿用任务状态/取消/30 秒与额度规则。不把 SEARCH 塞入原 AIClient mode 枚举。

完成 result:{searchState,claims,sources,hasConflict,partial}；searchState 为 SUCCESS 或 EMPTY，partial 表示部分检索适配器失败但仍有可核查结果；claims 每项

{id,summary,sourceIds}，sources 每项{id,title,url,publishedAt:null 或 instant,retrievedAt,quality}，quality=CURRENT/STALE/UNKNOWN。最多 10 个来源、10 条摘要，每条摘要最多 1000 码点。sources 为空时只能 EMPTY 并说明资料不足；来源不可访问、时间不明或冲突明确标记，不伪造时间和链接；检索执行失败是 failed，不能 EMPTY。

SearchProvider 只调用固定供应商端点；用户输入的 URL 当查询材料，不允许工具任意访问内网/本机/云元数据地址；对必要抓取的 URL 及每次重定向重新校验协议、解析 IP 和允许范围。网页文本不改系统规则。查询结果默认临时；只有 SUCCESS 且至少包含一项可核查来源时，用户才可在结果有效窗口内通过 POST /api/records 明确保存，使用 kind=QUERY、payload={searchRequestId} 和 SAVE 许可。服务端必须从本人当前入口的已完成查询复制问题、主张、来源和不确定性，客户端不得提交自造证据链；事务写入 saved_records、saved_queries、sources、claims、evidence_links。持久 SavedQueryStatus 按 CONFLICTED（hasConflict）、PARTIAL_SUCCESS（partial）、STALE_SOURCE（存在 STALE 来源）、SUCCESS 的顺序确定；EMPTY 和 failed 任务不可保存。庄剴涵主责、程群整理。

5.7 REQ04 模式切换

网络任务使用第 5.3.1 节 switch；前端独立 ModeController.switchTo(target,{selectedContextIds})先校验能力、提示携带范围、停旧训练/音频/物理活动，再切换网络业务会话。服务代次不符 409 时读取实际状态，不能在失败后复活旧请求。切向纯端侧功能只结束旧网络任务，不把本地正文自动创建为消息。切离 REQ14 直接清空独立 buffer，不提供携带内容选项。张王昊规则统筹，程杰/程群/李泉毅实现。

5.8 REQ05 会话和记录控制

方法/路径	输入/返回	校验、幂等与副作用
POST /api/records	{requestId,kind,payload,consentId}→201 Record	仅有效登录+SAVE；payload 与许可摘要一致；保存主表、子表、授权、幂等元数据同事务
GET /api/records	kind、cursor、limit 及类别过滤条件→200 {items,nextCursor}	本人当前入口；列表只含 id/kind/title/createdAt/updatedAt/version 及必要非正文状态，不返回全文

方法/路径	输入/返回	校验、幂等与副作用
GET /api/records/:id	无 body→200 Record	本人当前入口；不属于当前范围安全 404；DB 失败 503 不能假空
PATCH /api/records/:id	{requestId,expectedVersion,payload,consentId}→200 新 Record	不能改 kind/owner/entry；SAVE 绑定新载荷及原版本；更新版本+1；旧 AI 授权失效
POST /api/records/:id/clear-confirmations	{requestId,expectedVersion}→201 {confirmationId,expiresAt,recordId,version,kind}	本人、范围、版本匹配；只签发确认，不清除；2 分钟有效
POST /api/records/:id/clear	{requestId,expectedVersion,confirmationId,confirmed:true}→200 {cleared:true,recordId}	单次确认绑定身份/入口/版本；在事务内清主从数据、关联、授权及清除标记；取消时不发本请求

Record={id,kind,title,payload,createdAt,updatedAt,version}；owner/entry 由服务使用，不接受客户端指定。kind 统一为 CONVERSATION、EMOTION、WORRY_OBJECT、REHEARSAL_DRAFT、DEPOSIT、QUERY。CONVERSATION payload={title,sessionId,selectedMessageIds}，1～20 条当前身份当前活动消息，快照展开总正文最多 12000 码点；QUERY 保存请求 payload 仅为 {searchRequestId}，持久化返回内容由服务端从已完成查询生成。CONVERSATION 和 QUERY 首版快照只读，PATCH 这两类返回 409。其他 payload 见各 REQ 章节。

保存失败保留页面输入；清除失败不显示成功；成功清除后使该对象相关任务、选择引用和前端缓存失效，后续上下文不再访问。用户结束临时会话走第 5.3.1 节 END，不等于清除已保存记录。庄剴涵数据、李泉毅 API。

5.9 REQ06 多入口及桌宠

GET /api/capabilities 读取当前可信入口，200 {entry,features:[{reqId,status,reason?,fallback?}]}；status=AVAILABLE/SIMULATED/UNAVAILABLE。请求不接受任意 entry 查询作为授权依据；前端隐藏按钮不能替代服务拒绝。首发 WEB 全业务页面，REQ13 为页面画布；Electron 原生桌面浮层必须经验证才 AVAILABLE；微信文字销毁只可跳独立本地页面，不能把销毁正文放聊天或跳转参数。

Electron 只向渲染层暴露白名单 preload 桥：petWindow.move({x,y})、setAlwaysOnTop(boolean)、setClickThrough(boolean)、close()、getCapabilities()；数值为有限整数，移动限制在当前可见工作区，防止窗口拖丢；IPC 主进程校验调用窗口和参数。渲染层不启用 Node 集成，开启 contextIsolation 与 sandbox，不暴露通用 invoke/execute/shell/文件读写；固定加载受控界面，阻止任意导航。密钥不在安装包中。点击穿透失效时有可达的退出/恢复入口；具体快捷键由交互验证确定。

DESKTOP 业务登录需绑定可信入口和凭据，不能复用 WEB 会话后改个 header 冒充桌面身份。程杰主责，曾俊涛/关欣复核。

5.10 REQ07 安全与隐私

授权/撤销接口见第 5.3.2 节；其余为全局服务拦截规则，不额外创建“安全正文上传”接口。普通输入统一参数/归属/入口/用途校验；权限矩阵涵盖游客、本人、他人、同账号其他入口、失效会话。SafetyPolicy 检查输入和模型回复；明显危机场景停止常规引导，给出经维护的现实支持文案，不称自动救援；具体资源在部署地区核验。

REQ14 页面禁止接入通用会话 Context、日志、错误上报和分析 SDK；所有用户文本以文本渲染，检索摘要不直接插入任意 HTML。关欣主责。

5.11 REQ08 情绪与事件日历

复用 records，kind=EMOTION，payload={date,emotionWords,intensity,event,timeZone}；event 可空，timeZone 为服务允许的 IANA 时区。GET /api/records?kind=EMOTION&from=YYYY-MM-DD&to=YYYY-MM-DD&...，单次日期跨度最多 366 天并分页；返回列表可带 date/emotionWords/intensity，不含 event 正文。允许同日多条，按 createdAt 排序；不额外创建“每日唯一”约束。详情/修改/清除走通用路径。

游客可本地填写，保存前登录后必须重新主动提交，不自动迁移。保存不能触发 AI 或趋势分析；无记录为空，失败走错误。庄凯涵主责。

5.12 REQ09 情绪命名卡

端侧 NamingCard.select({emotionWords,need})；need=LISTEN/ORGANIZE/SEARCH，返回 {targetMode,emotionWords,requiresQuestion}，未选 need 不路由。命名选择不单独上

传/落库；需要进入 AI 或查询时才经第 5.3 节/第 5.6 节许可传必要选词。SEARCH 缺具体问题先在页面澄清，不能直接把“烦躁”当事实问题去检索。另选“写入日历”进入 REQ08 编辑页，再主动保存。程群/郭昱祺负责。

5.13 REQ10 烦恼物件化

端侧形状枚举 TANGLE/STONE/NOTE；draft={shape,title,description?}，description 允许不填。放旁边仅显示外观，不创建 AI 任务。保存 kind=WORRY_OBJECT，payload={shape,title,description?}；只保存外观时省略 description，不能把隐藏文本随包提交。

GET /api/room→200 {id:null 或 UUID,version:0 或正整数,objects:[{recordId,shape,x,y}]}；要求有效登录，仅本人当前入口；游客只用本地临时房间，不调用持久化接口。无持久房间返回空，失败不能假空。PUT /api/room 输入 {requestId,expectedVersion,objects}，200 新版本；创建 expectedVersion=0、修改匹配现版。objects 最多 30 个，各 recordId 不得重复且均为本人本入口已保存物件，x/y 归一化 0～1；清除物件时同事务去除房间关联。移出房间只是取消关联，不清正文。

梳理走 OBJECT_ORGANIZE，读取已保存物件必须 resourceId+resourceVersion 并获 AI 许可，或使用已授权 objectDraft；不可从形状推断原因，不带其他物件。程群/程杰、庄剴涵协作。

5.14 REQ11 平行宇宙排练

REHEARSE 会话+REHEARSAL_REPLY，必须 simulation 且清楚展示 AI 模拟。暂停/继续/重来走第 5.3.1 节动作；重来建立新活动代次，清掉上轮可选表达。用户点击“结束模拟并整理”执行 FINISH_REHEARSAL：停止角色回复、递增活动代次并撤销旧任务/许可，进入 reviewing，暂保留本轮本人消息供选择；这不同于 END 清空会话。reviewing 仅允许认可表达选择、REHEARSAL_SUMMARIZE、主动保存、重来或 END，不允许继续角色回复。服务端将本人消息与 AI 消息分别标角色，客户端提交 recognizedMessageIds 不能包含 AI 生成但未经本人表达的消息；首版认可范围为本人当前轮次消息。

REHEARSAL_SUMMARIZE 只把选定认可表达及必要场景发给模型，不发送整轮对话。生成整理稿是预览，用户可编辑后主动保存；保存 kind=REHEARSAL_DRAFT，payload={scene,sessionId,activityId,recognizedMessageIds,expressions}，expressions 1～20 条非空文本、总计最多 12000 码点。服务检查当前认可选择和用户提

交确认，不允许自动把未认可建议加入稿件；若改写偏离原意，用户修改/取消，不把模型输出直接当本人认可。

普通记录 PATCH 编辑稿件需 SAVE，不能扩大 AI 用途；完整排练对话不持久化。程群主责、程杰 UI。

5.15 REQ12 烦恼寄存

kind=DEPOSIT，payload={title,body,reopenAt}；reopenAt 严格晚于当前时刻；records 列表只含标题/到期时间/state，不返回 body。到期仅 STORED→AVAILABLE 并递增 version，在事务/读取时校正；GET 不能把正文放到到期提示中。进程重启按 DB 时刻重新计算，不依赖浏览器计时。

POST /api/deposits/:id/retrieve 输入{requestId,expectedVersion}→200 {id,state:RETRIEVED,version,body}，必须到期且本人主动；未到期 409。POST /api/deposits/:id/postpone 输入{requestId,expectedVersion,reopenAt}→200 {id,state:STORED,version,reopenAt}，未来时间、乐观锁更新；GET 详情对尚未主动取出的条目不返回 body（编辑未到期正文首版不开放）；通用 records PATCH 对 DEPOSIT 首版拒绝，延期只用 postpone；已取出可看正文但不自动发 AI。清除仍需确认。庄剀涵主责。

5.16 REQ13 屏幕无损发泄

无 HTTP 敲击事件接口。端侧 ImpactController.start({effect,muted,volume})、hit({x,y,strength})、pause/resume/reset/stop()；effect 限定预置枚举，volume/strength 为 0～1，坐标限制视图；Web 仅画布区域；Electron 浮层依 REQ06 能力验证。退出/Escape 释放点击捕获、动画帧、音频和监听，静音立即停止现有声音。程杰主责。

5.17 REQ14 文字销毁

无 HTTP/Agent/仓储接口，也没有“远程销毁”“恢复草稿”“上传正文校验”路径。独立组件内 setBuffer(text)（最多 4000 码点）、destroy(effect)、clear()、dispose()；effect=SHRED/BURN/BLACK_HOLE。正文只在视图私有内存，不带账号 ID；切换/结束/关闭时清空，跳过动画也清空。销毁页资源本地打包，不依赖第三方脚本/字体/CDN 或远程遥测；禁止任何包含正文的请求、日志、URL、持久存储或崩溃附件。

这里的产品功能清空是用户主动操作，不涉及删除工作区文件。仅保证产品控制的数据通路，不承诺操作系统交换文件、输入法或恶意扩展绝对无痕。程杰实现、关欣专项、曾俊涛取证。

5.18 REQ15 禅意编曲弹珠机

无 HTTP 轨迹/碰撞/音符接口。端侧 MarbleController.configure(layout)、release(ball)、pause/resume/reset/stop()和 setMuted(boolean)；构件类型与音阶仅选预置；坐标在画布内；暂停停物理和新音符，静音停止现有声音，重置清球，退出销毁循环和音频节点。布局首版临时，不默认保存或跨入口同步。程杰主责。

5.19 REQ16 注册、登录与改密

方法/路径	输入	返回/限制
GET /api/auth/context	无 body	200 {authenticated,csrfToken,expiresAt?}；建立匿名上下文或读取当前身份，不返回原始 Cookie
POST /api/auth/register	{requestId,loginName,password,confirmPassword}	201 {accountId}，不自动登录；标准化唯一索引原子检查；密码一致且 12～128
POST /api/auth/login	{loginName,password,target}	200 {profile,target,expiresAt} + Set-Cookie；target 为固定页面键，禁止任意跳转 URL；凭据错误统一反馈
POST /api/auth/logout	无正文；CSRF 头必需	204，撤销当前会话、清 Cookie、取消相关临时任务；已退出再次请求安全清 Cookie
POST /api/auth/change-password	{currentPassword,newPassword,confirmPassword}	204，校验旧摘要并原子更新；撤销所有旧登录会话和任务，清 Cookie；成功后重新登录

登录名唯一冲突 409，但登录错误不区分不存在账号/错误密码；失败提示不回显凭据。账号和 IP 分别 5 次失败/15 分钟限速，窗口到期再试，不永久锁账号；注册按 IP 初始 10 次/小时，改密按账号 5 次失败/15 分钟。登录成功轮换匿名/旧会话，失效并清理旧临时内容；需要保存游客内容时先由用户在客户端保留选择，登录后再次明确提交，不把旧匿名会话自动认领给账号。

login_sessions 字段至少 id/account_id/token_digest/entry/device_id/issued_at/last_seen_at/expires_at/revoked_at；token_digest 唯一索引，必要 account_id 与有效状态索引。用 node:crypto 生成至少 32 随机字节凭据，存 SHA-256 摘要，凭据不入 JSON、日志和 URL；密码 Argon2id 初始 19MiB、迭代 2、并行度 1 及独立随机盐。空闲 30 分钟、绝对 7 天，last_seen 在服务端校验并按短间隔批量更新，不能依靠客户端延长。批量更新策略不能跳过本次请求的超时判断。

不引入另一套并行 express-session 状态；AuthService/IdentityRepository 统一负责会话。退出记录不清业务记录；备份恢复后所有旧登录会话强制失效，不能将备份里的有效会话直接恢复上线。李泉毅主责、庄凯涵 DDL、关欣审查。

5.20 REQ17 私密个人主页

方法/路径	输入/返回	限制
GET /api/profile	→200 {nickname,avatarKey,bio,version}	有效本人身份；不提供 public/:id 路径
PATCH /api/profile	{requestId,expectedVersion,nickname,avatarKey,bio}→200 新资料	avatarKey 仅预置资源键；1～32 昵称/0～200 简介；事务版本更新
GET /api/profile/summary	→200 {counts:{CONVERSATION,EMOTION,WORRY_OBJECT,REHEARSAL_DRAFT,DEPOSIT,QUERY}}	只统计本人当前入口；不含情绪评分、正文、销毁次数；失败 503 不返回全零
GET /api/preferences	→200 {offerHistorySave,version}	仅提示偏好，不是保存授权
PATCH /api/preferences	{requestId,expectedVersion,offerHistorySave}→200 新偏好	不自动保存/分析/共享；登录过期拒绝

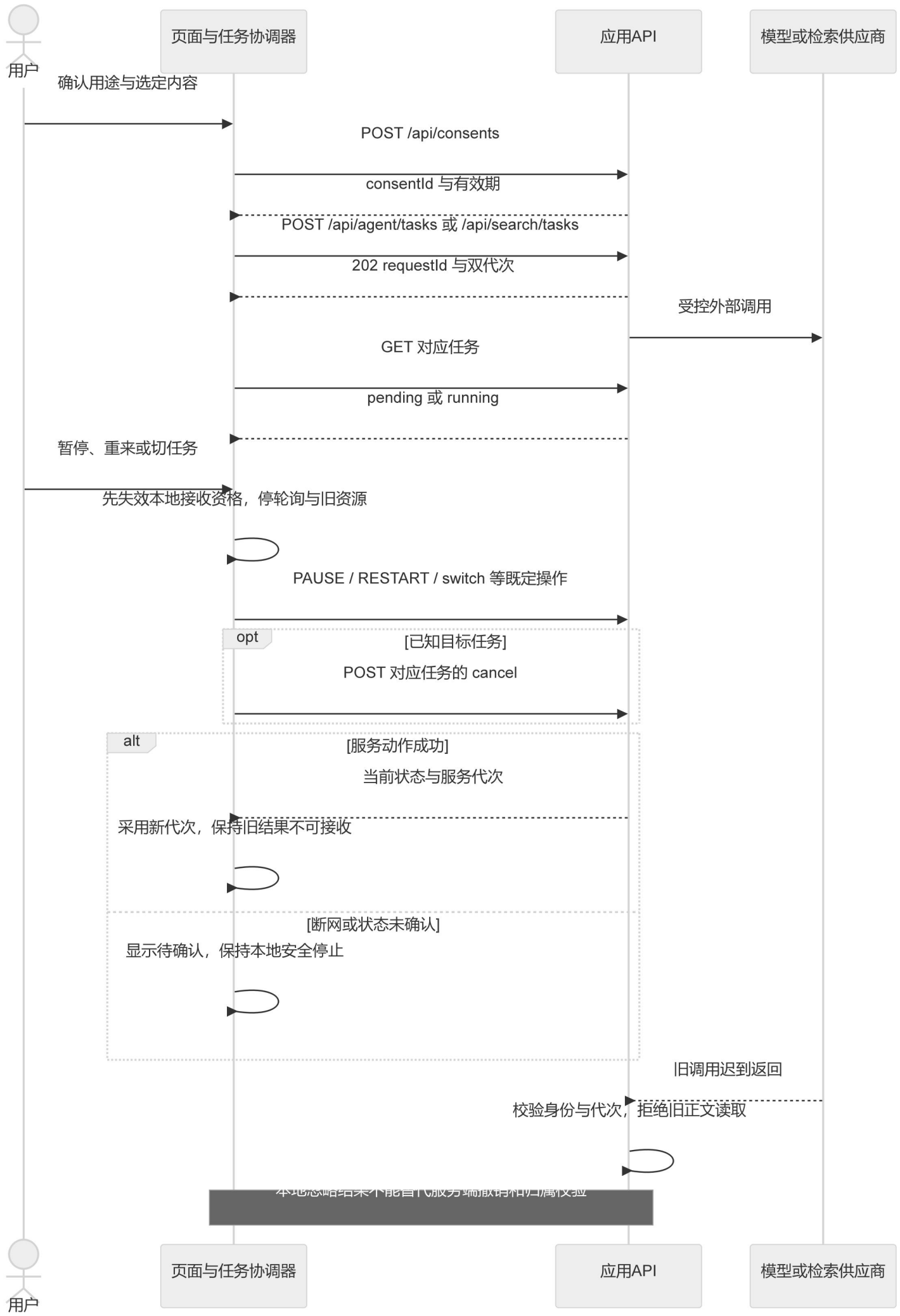
设备静音/音量/减少动态效果/桌宠显示使用单独设备偏好存储，只保存非正文配置；不得将业务文本塞进偏好。资料修改不新增 AI 外发权限，账号级资料与入口级私密记录区分。郭昱祺产品，李泉毅服务。

6 运行过程与关键状态

6.1 任务控制与迟到回复

请求在发送前绑定身份、可信入口、业务会话、活动及 sessionGeneration 和 activityGeneration。暂停、重来、结束、切换、撤回许可或身份变化先屏蔽结果，再取消任务。底层供应商未能终止不能成为回填旧结果的理由。

图 6-1 外部任务与迟到结果时序

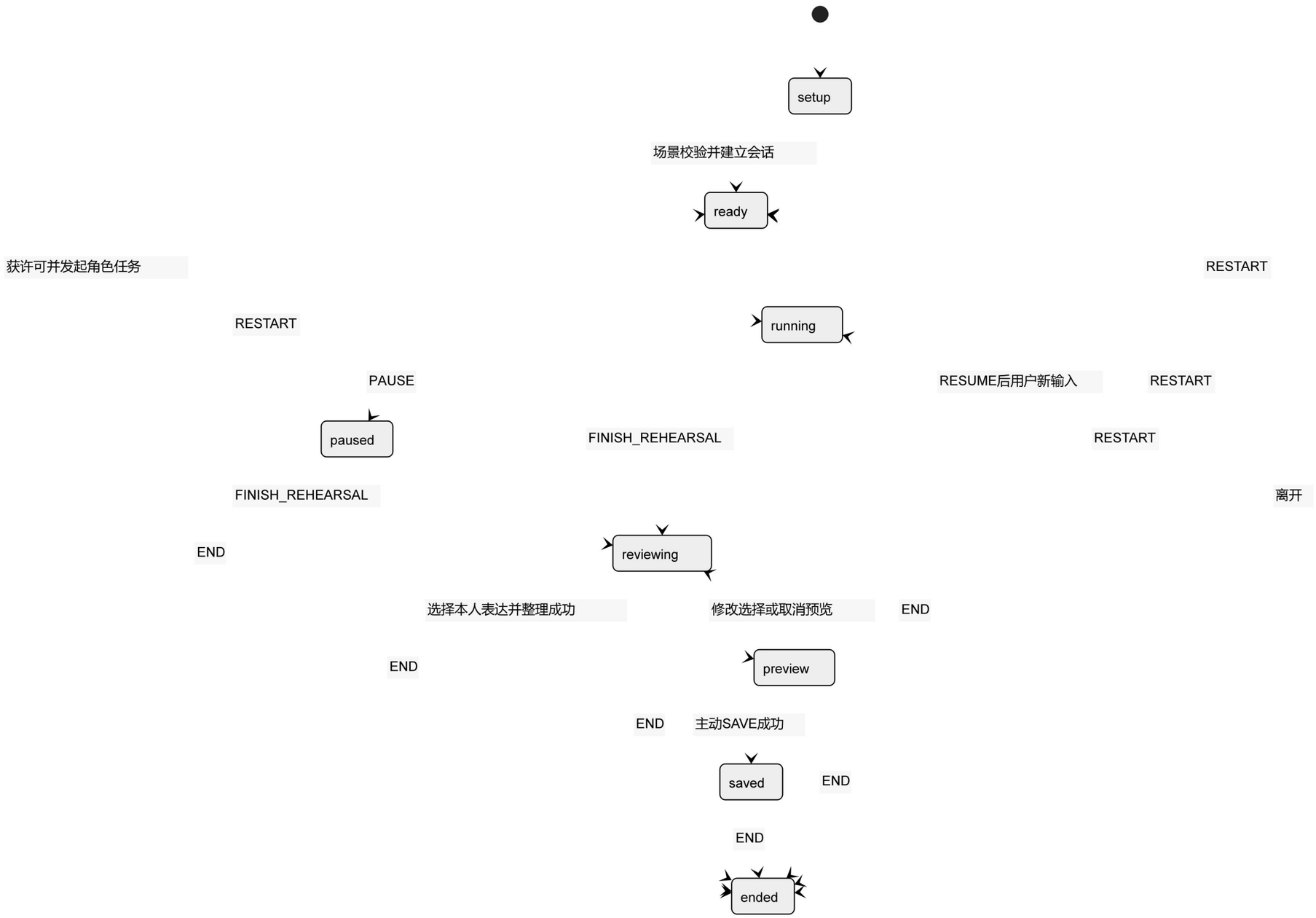


图源：仓库固定提交 fe60c90c1ed3；原始模型完整呈现。

6.2 沟通排练

阶段	进入条件	允许操作	API / 领域映射	退出与清理
setup	打开排练设置	填写 scene、counterpart、goal、style	尚未创建活动	取消即清临时场景
ready	创建 REHEARSE 会话成功	开始、END	ActivityState.READY	END 清临时数据
running	REHEARSAL_REPLY 受理	发言、PAUSE、RESTART、FINISH_REHEARSAL、END	ActivityState.RUNNING	控制动作先失效旧任务
paused	PAUSE 成功	RESUME、RESTART、FINISH_REHEARSAL、END	ActivityState.PAUSED	RESUME 不重放旧请求
reviewing	FINISH_REHEARSAL 成功	选择本轮本人消息、整理、RESTART、END	应用阶段；停止角色回复并递增 activityGeneration	撤销旧许可；禁止继续角色回复
preview	REHEARSAL_SUMMARIZE 完成且代次有效	审阅、编辑、保存、返回选择	临时整理稿，不等于已保存记录	修改选择使旧预览失效
saved	POST /api/records 成功且结果已核实	确认后 END	REHEARSAL_DRAFT 持久记录	仅保存认可表达，不存整轮排练
ended	END 成功	无	会话结束	清对话、选择、预览、任务和临时许可

图 6-2 排练与物件关键状态



图源：仓库固定提交 fe60c90c1ed3；原始模型完整呈现。

6.3 保存清除与不确定写结果

1. 写请求以 (accountId, entryPointId, operation, requestId) 作为幂等作用域，对规范化载荷计算 payloadDigest。

2. 首次请求在同一数据库事务登记 IN_PROGRESS；业务写、版本变更、授权消耗和幂等结果一起提交为 COMPLETED。元数据只保存摘要、结果类型、结果 ID/版本、HTTP 状态和期限，不复制正文。

3. 同作用域、同 requestId、同摘要的重试返回原结果；摘要不同返回 409 CONFLICT；仍在执行返回 409 INVALID_STATE。

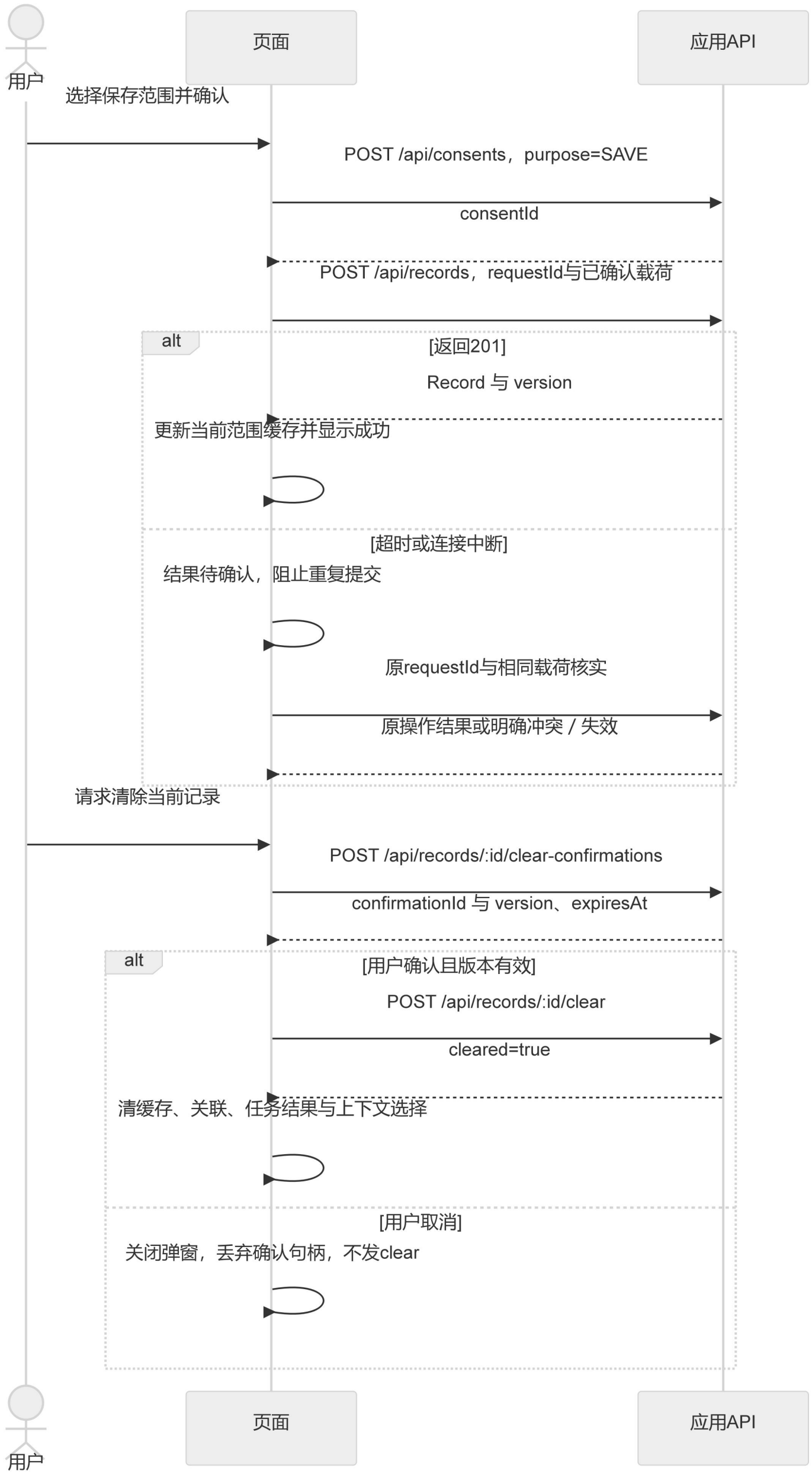
4. 网络断开或 5 秒超时后，客户端以原 requestId 与完全相同载荷重放核实，不得换新 ID 重复写。取得结果 ID 后再调用既有 GET 端点核对。

5. SAVE 许可过期不影响读取已提交的幂等结果；若事务未提交且许可已过期，服务不得继续写入，应要求用户重新确认。不得复活已清除正文。

6. 持久幂等元数据保留 24 小时；AI / Search 任务幂等仍为进程内临时态，不承诺跨重启。

数据库落地采用 idempotency_records（或数据库专业稿批准的等价表），唯一键覆盖账号、入口、操作和 requestId；saved_records 与 deletion_jobs 现有入口作用域唯一约束继续作为业务表第二道保护。DDL、ER、数据字典必须按第 8 节变更项同步后才视为跨稿闭环。

图 6-3 主动保存与清除时序



图源：仓库固定提交 fe60c90c1ed3；原始模型完整呈现。

6.4 停止与资源回收

每个活动用 ResourceScope 登记 timer、requestAnimationFrame、监听、指针捕获、AudioNode / 音源、物理对象和效果缓存。暂停停推进与在播声音；继续由用户触发；重置清旧运行状态；退出与窗口销毁执行幂等释放。静音必须立即停止现有声音，不能只禁止后续音符。具体状态表见 03 号文档。

7 数据协作设计

7.1 临时与持久对象

分类	示例	默认状态	允许存储位置	敏感级别
D0 临时端侧	文字销毁正文、浮层输入、弹珠运行态	关闭/退出即清理	端侧内存	高
D1 临时服务态	陪伴/训练/排练未保存上下文、检索中间结果	请求结束或超时清理	服务内存	高
D2 主动保存正文	用户保存的会话、寄存正文、认可表达	用户选择后保存	加密业务表	高
D3 结构化记录	情绪词、强度、物件外观、状态、日期	用户点击保存后保存	业务表	中高
D4 检索证据	来源元数据、主张、证据关系	仅随保存查询保存	证据表	中
D5 安全元数据	会话撤销、授权、删除作业、最小审计	按策略保留	安全/治理表	中高

7.2 类与表映射

设计类/服务	数据表	说明
AuthService / UserAccount / PasswordCredential	user_accounts、password_credentials	账号与密码摘要分离；不提供找回/重置

设计类/服务	数据表	说明
LoginSession / IdentityRepository	login_sessions、entry_points	凭据摘要、撤销和入口隔离
ProfileService / UserProfile / AccountPreferences	user_profiles、account_preferences	私密主页及账号级偏好，不等于公开主页
RecordService / SavedConversation	saved_records、saved_messages	只保存用户选定的消息快照
EmotionRecord	saved_records、emotion_records	只记不分析；按账号+入口+日期访问
WorryObject / PetRoom	saved_records、worry_objects、rooms、room_objects	房间聚合独立版本；复合外键保证房间、物件同账号同入口；外观关联与正文清除分离
RehearsalSession / AcceptedExpression	saved_records、rehearsal_drafts	只保存用户认可表达
WorryDeposit	saved_records、worry_deposits	到期状态不自动展开
SearchProvider / SearchOrchestrator	saved_records、saved_queries、sources、claims、evidence_links	中间结果临时，保存后形成证据链
ConsentService / ConsentGrant	consent_grants	保存、AI、检索、分析与跨入口用途；绑定范围、对象版本、有效期和撤回
DeletionService	deletion_jobs、deletion_targets、deletion_outbox、deletion_log_entries	主库/索引/缓存/备份传播及恢复重放
AuditService	audit_events	最小元数据，禁止正文和密码

7.3 事务与恢复协作

主动保存将父表、类型子表、必要许可元数据置于同一 pg 连接的事务内。清除立即使对象不可见，并同事务产生删除任务、目标及 outbox；后台重试传播不包含正文。模型和搜索不占用数据库长事务。数据库详细字段、约束、索引、恢复和 ER 见配套数据库设计说明书。

8 安全与权限设计

8.1 权限判定

授权判定为有效身份、账号归属、可信入口、对象版本及用途许可的联合条件。本人记录读取还需未删除；更新校验 expectedVersion；保存、AI 外发和检索用途彼此独立。其他账号或入口访问对象统一安全 404，不泄露对象是否存在。

主体与对象范围	临时体验	私密读取	保存与更新	外部模型或搜索	清除
游客且匿名上下文有效	允许受限临时功能	禁止	禁止持久保存	对当前载荷取得独立用途许可后允许	只清当前端侧临时内容
本人且当前入口登录有效	允许	只读本人同入口未删除对象	主动 SAVE 许可，更新再验版本	每次按目的、载荷、对象版本验证许可	短时单次确认，归属及版本匹配
同账号另一入口	独立临时体验	默认拒绝	不能修改当前入口对象	不自动带入其他入口历史	默认拒绝
其他账号或失效会话	按游客边界重新开始	拒绝并遮蔽正文	拒绝	不外发原身份正文	拒绝
应用运维与备份流程	不属于业务用户	不提供产品正文浏览入口	仅职责内技术操作	无模型或搜索权限	依可靠清除任务与恢复规则执行

8.2 安全措施与失败行为

风险	执行位置与措施	可观察拒绝或恢复行为
凭据泄漏	Argon2id 带盐摘要；32 随机字节会话凭据，数据库仅 SHA-256 摘要；HttpOnly Secure SameSite Cookie	退出撤销当前会话，改密撤销全部旧会话；原始凭据不进入 URL 与日志
伪造写请求	接入层验证会话绑定 CSRF 与允许 Origin；严格 Zod 校验未知字段和长度	403 拒绝，无写库和外部调用
水平越权	AuthorizationPolicy 建立 AccessContext，Repository 参数化 SQL 附 account_id 及 entry_point_id	不存在、他人、其他入口均安全 404

风险	执行位置与措施	可观察拒绝或恢复行为
并发覆盖	持久对象版本条件更新；归属和版本同一原子语句校验	409 并读取权威状态，由用户决定后续
SQL 注入与 XSS	参数化查询；排序及资源键白名单；正文按纯文本渲染	非法输入 400，不执行脚本、不回显 SQL 错误
提示注入与 SSRF	网页和模型输出作资料；检索固定端点；抓取与重定向逐次校验目标 IP	不执行外来指令，不访问内网或云元数据
过量请求	哈希前限流；每账号单个外部任务；单实例并发 4 队列 8；30 秒总时限	429 及重试间隔，取消不受生成额度阻断
日志泄漏	不记录正文、Cookie、提示词和 SQL 参数；仅状态、耗时、非正文标识	供应商错误转换为安全错误码，崩溃附件无正文
桌面进程滥用	渲染层无 Node 权限，contextIsolation 与 sandbox；preload 仅白名单窗口操作	非法 IPC 与导航拒绝，失败时降级普通窗口

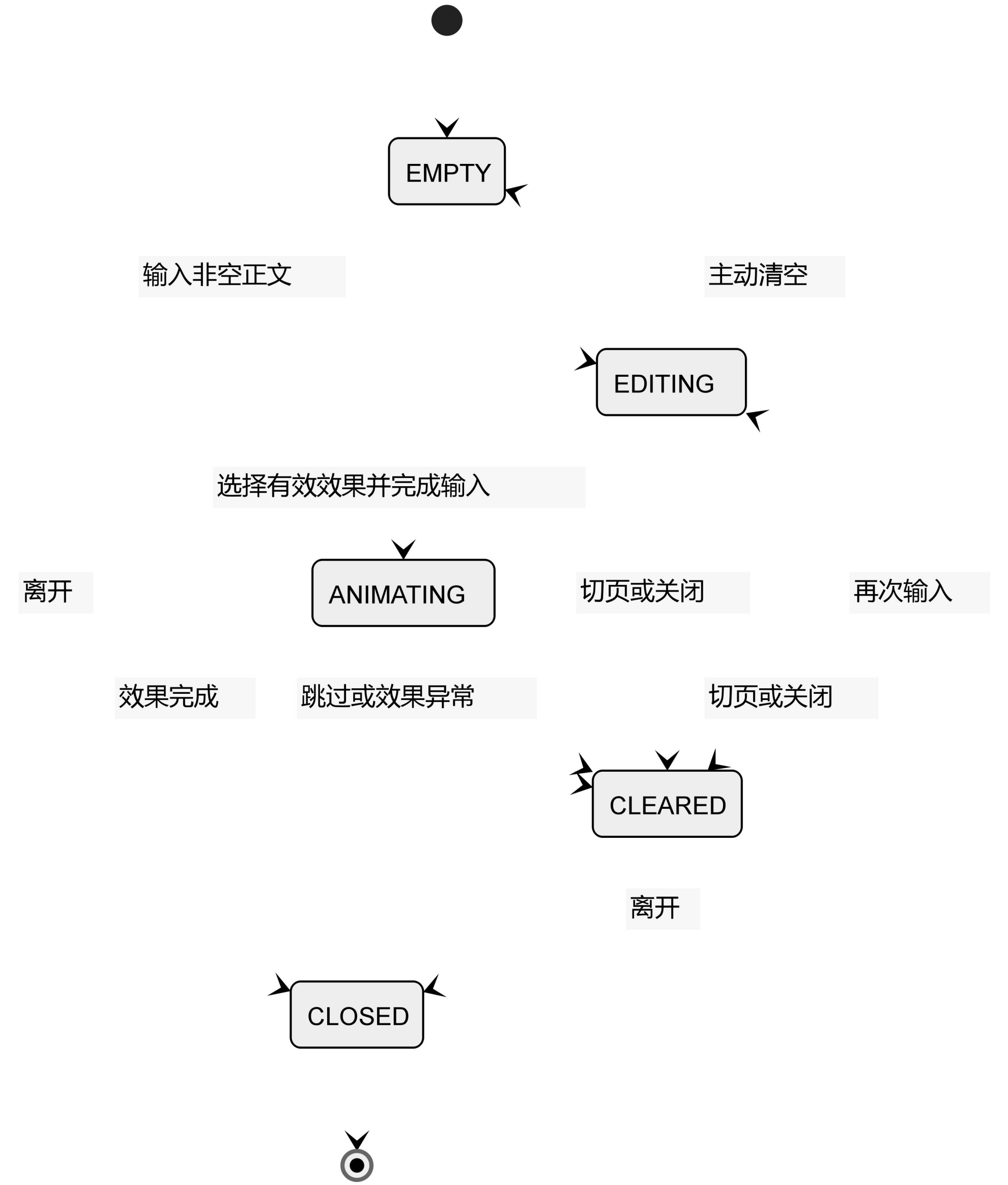
8.3 文字销毁独立通路

独立销毁页面只允许 setBuffer(text)、destroy(effect)、clear()、dispose()。正文最多 4000 Unicode 码点，仅存在本视图，不经过通用聊天状态、账号状态、记录缓存、浏览器持久存储、网络、AI、搜索、日志、错误上报、会话回放或遥测。

资源随包提供，不加载第三方脚本、字体或 CDN。页面部署可使用禁止网络连接的 CSP；需要的样式、图像等仅来自本地受控资源。效果异常只给固定错误文案，不序列化输入或含正文异常对象。

clear() 清空输入 DOM、私有 buffer、拆字节点、粒子文本、纹理与相关闭包引用；dispose() 进一步取消动画帧、监听与指针捕获。跳过动画与正常完成执行同一清理。关闭页不能依赖异步上传或退出回调才能完成清理，输入过程中也始终没有持久副本。边界限定于本产品控制的数据通路，不承诺操作系统或输入法绝对无痕。

图 8-1 文字销毁状态与清理



图源：仓库固定提交 fe60c90c1ed3；原始模型完整呈现。

8.4 内容与危机边界

SafetyPolicy 遇明显危机表达停止常规引导，给经产品审核的现实支持提示；不作诊断或自动救援承诺。模型不能自行访问私密历史、扩大许可或执行网页指令。固定训练和命名路由不强制调用模型。

9 部署维护与健壮性

9.1 运行配置

开发环境本机运行；目标环境同源 Web 静态资源与 Express API，数据库私网可达，首版单实例。运行时与依赖版本由实际锁文件和部署记录登记，不把未实现依赖写成现有工程。模型厂商、版本、密钥、预算和云资源在部署前配置，密钥仅服务端注入。

9.2 故障处理

故障	处理	恢复条件
数据库不可用	私密读取 503，不显示空历史；写入结果待核实	使用原 requestId 同载荷核实，不重复提交
模型或检索超时	任务 failed 并给 TIMEOUT，不以 EMPTY 掩盖执行失败	用户手动重试，重新校验许可和额度
断网退出	立即遮蔽正文并停本地任务；不声称撤销已成功	联网确认撤销前不重读正文
服务重启	临时会话与任务失效，不自动重发正文	用户明确重新开始；持久数据从授权读取
Electron 异常	主进程兜底销毁浮层，释放声音与捕获	记录受限能力并降级 Web 画布
恢复旧备份	隔离环境先重放独立清除日志，撤销旧登录	连续性验证与复核后开放，失败则停止发布

9.3 维护与变更

变更先登记影响的 REQ、接口、类、表和验收，再同步共享契约、客户端与数据库迁移。部署前备份已持久数据，迁移使用独立账号；回退须评估新旧应用与表结构兼容，不在缺少迁移验证时声称可一键回滚。只观测脱敏状态与用量。